



دولة ليبيا
وزارة التعليم العالي والبحث العلمي
جامعة سبها
كلية تقنية المعلومات
قسم الشبكات و الاتصالات

بحث مقدم لاستكمال متطلبات نيل درجة البكالوريوس في الشبكات و الاتصالات
تحت عنوان

Open-Source SOC Automation Framework for IOC-driven Incident Response

نموذج مفتوح المصدر لأتمتة مركز العمليات الأمنية للاستجابة للحوادث المعتمدة على
مؤشرات الاختراق

إعداد:

محسن طاهر محمد
الطاهر حسن الطاهر

إشراف:

أ.سلوى عبدالنبي

للعام الجامعي

2025 - 2026 م

إقرار

إقرار الطالب / الطلاب

أنا الطالب: الرقم الدراسي:

أنا الطالب: الرقم الدراسي:

نقر بأن ما ورد في هذا البحث هو من مجهودنا الشخصي ماعدا الفقرات التي تم إسنادها إلى مرجع.

التوقيع: التاريخ:

التوقيع: التاريخ:

إقرار المشرف

اسم المشرف: أ.سلوى عبدالنبي

أقر بأني اطلعت على مادة البحث، وأن البحث جاهز للمناقشة.

التوقيع: التاريخ:

إقرار بالموافقة على التصحيحات وتسليم النسخة النهائية:

بعد التصحيح والاطلاع على مادة البحث، تمت الموافقة عليها، وتسليم النسخة النهائية.

اسم الممتحن الأول: التوقيع:

التاريخ:

اسم الممتحن الثاني: التوقيع:

التاريخ:

الآية

بسم الله الرحمن الرحيم

{ اقْرَأْ بِاسْمِ رَبِّكَ الَّذِي خَلَقَ (1) خَلَقَ الْإِنْسَانَ مِنْ
عَلَقٍ (2) اقْرَأْ وَرَبُّكَ الْأَكْرَمُ (3) الَّذِي عَلَّمَ بِالْقَلَمِ (4)
عَلَّمَ الْإِنْسَانَ مَا لَمْ يَعْلَمْ (5) }

سورة العلق الآيات (1-5)

الإهداء

بسم الله الرحمن الرحيم، والحمد لله رب العالمين، والصلاة والسلام على خاتم الأنبياء والمرسلين سيدنا محمد، وعلى آله وصحبه ومن تبعهم بإحسان إلى يوم الدين، أما بعد:

نحمدُ اللهَ جلَّ وعلا على ما آتانا من فضله، إذ هَيَّاَ لنا السُّبُلَ ويسَّرَ لنا إنجاز هذا العمل بعظيم كرمه وواسع إحسانه، فله الحمد أولاً وآخراً، ظاهراً وباطناً، على كل نعمه التي لا تُعد ولا تُحصى.

نهدي هذا العمل إلى من نُقَدِّمهم على أنفسنا، الذين بذلوا الغالي والنفيس في سبيل سعادتنا، ولم يدَّخروا جهداً في دعمنا ومساندتنا على الدوام، إلى أمهاتنا العزيزات اللاتي كنَّ نبع العطاء والحنان، ومصدر القوة والصبر.

وإلى من كانوا لنا قدوةً في الجد والاجتهاد، وسنداً في مسيرتنا العلمية والعملية، أصحاب السيرة الحسنة والخصال الطيبة الذين لم ييخلوا علينا بعطائهم، إلى آبائنا الأفاضل.

كما نتقدّم بخالص الشكر والتقدير إلى إخوتنا وأخواتنا، وإلى كل من وقف إلى جانبنا وساعدنا بكل ما يملك، في مختلف المجالات.

ونخصّ بالذكر مشرفة البحث الأستاذة سلوى عبد النبي، لما قدّمت لنا من توجيهات علمية قيّمة، ومتابعة جادة أسهمت في إنجاز هذا العمل وإخراجه بالصورة المطلوبة، فلها منا جزيل الشكر وعظيم الامتنان، ونسأل الله أن يجزيها عنا خير الجزاء.

وآخر دعوانا أن الحمد لله رب العالمين.

كلمة شكر وتقدير

عملاً بقول رسول الله صلى الله عليه وسلم: "من لا يشكر الناس لا يشكر الله"، وامتثالاً لتوجيهه الكريم: "مَنْ صَنَعَ إِلَيْكُمْ مَعْرُوفًا فَكَافِئُوهُ، فَإِنْ لَمْ تَجِدُوا مَا تَكَافِئُونَهُ فَادْعُوا لَهُ حَتَّى تَرَوْا أَنْكُمْ قَدْ كَافَأْتُمُوهُ".

ننتقد بعظيم الشكر وجزيل الامتنان لكل عضو من أعضاء هيئة التدريس الذين رافقونا طيلة السنوات الدراسية الماضية، والذين لم يبخلوا علينا بفيض علمهم ومعرفتهم، فنسجل لهم كل التقدير والعرفان.

ونخص بالذكر الأستاذة الفاضلة سلوى عبد النبي، نشكرها من أعماق قلوبنا على الدعم والمساندة المستمرة لإتمام مشروع التخرج هذا، دمت لنا خير قدوة ومثال يُحتذى به.

كما ننتقد بخالص الود وصادق الدعوات إلى عائلاتنا الكريمة، التي كانت لنا السند والملاذ، والتي تحملت معنا الكثير ووفرت لنا بيئة داعمة ومحفزة لنصل إلى هذه اللحظة التي نقطف فيها ثمار الجهد والتعب.

وأخيراً، شكرٌ خاص ومفعم بالمحبة إلى الأصدقاء والأحباء الذين شاركونا فرحتنا، ومدّوا لنا يد العون، وكانوا خير سندٍ لنا طوال مسيرتنا العلمية، بجلوها ومُرّها.

فهرس المحتويات

I	إقرار
II	الآية
III	الإهداء
IV	كلمة شكر وتقدير
V	فهرس المحتويات
X	فهرس الأشكال
XI	فهرس الجداول
XII	قائمة الاختصارات
XIV	الملخص
1	الفصل الأول
2	1. المقدمة
3	1.1 مشكلة البحث
3	2.1 أسئلة البحث
4	3.1 أهداف البحث
4	4.1 أهمية البحث
5	5.1 حدود البحث
6	6.1 منهجية البحث
6	7.1 هيكلية البحث
8	الفصل الثاني
9	2. تمهيد
9	1.2 الأمن السيبراني
9	1.1.2 مفهوم الأمن السيبراني وأهميته
10	2.1.2 التحديات الأمنية المعاصرة

10	3.1.2 آليات المواجهة (الدفاع في العمق).....
10	2.2 مركز العمليات الأمنية (Security Operation Center – SOC)
10	1.2.2 المفهوم والمكونات
11	2.2.2 أنواع مراكز العمليات الأمنية.....
	3.2 أنظمة ادارة المعلومات والاحداث الامنية (Security Information and Event Management - SIEM)
11	
12	1.3.2 منصة Wazuh
	4.2 التنسيق والأتمتة والاستجابة الأمنية (Security Orchestration, Automation, and Response -)
13	(SOAR)
13	1.4.2 منصة n8n
14	5.2 الاستجابة للحوادث (Incident Response - IR)
14	1.5.2 دورة حياة الاستجابة.....
14	2.5.2 منصات إدارة القضايا (Case Management Platforms)
15	6.2 استخبارات التهديدات.....
16	1.6.2 منصة (Malware Information Sharing Platform - MISP)
16	7.2 تقنية الحاويات البرمجية (Containerization)
16	1.7.2 منصة Docker
17	8.2 أدوات القياس ومؤشرات الأداء
17	1.8.2 زمن الاكتشاف الآلي (Automated MTTD)
17	2.8.2 زمن الاستجابة الآلي (Automated MTTR)
17	9.2 مؤشرات الاختراق (Indicators of Compromise - IOCs)
18	10.2 جمع البيانات الطرفية والمراقبة المجهريه
18	1.10.2 أداة Sysmon (System Monitor)
19	2.10.2 أدوات جمع السجلات.....
19	11.2 بروتوكولات التكامل والربط البرمجي.....

19	1.11.2 واجهات برمجة التطبيقات (Application Programming Interface - API)
20	2.11.2 نظام Webhooks
20	3.11.2 صيغة تبادل البيانات (JavaScript Object Notation - JSON Format)
21	4.11.2 أثر التكامل البرمجي على كفاءة العمليات الأمنية
21	12.2 التقاطع بين الإطار النظري ونطاق البحث الجاري
22	13.2 الدراسات السابقة
22	1.13.2 الدراسات المتعلقة بأنظمة SIEM مفتوحة المصدر (Wazuh)
23	2.13.2 الدراسات المتعلقة بأتمتة سير العمل (n8n)
23	3.13.2 الدراسات المتعلقة بإدارة الحوادث وتحليل المؤشرات (Cortex و TheHive)
23	4.13.2 الدراسات المتعلقة باستخبارات التهديدات ومشاركتها (MISP و OTX)
24	5.13.2 الدراسات المتعلقة بالتكامل الشامل وأتمتة الاستجابة
24	6.13.2 الدراسات المتعلقة بجمع البيانات المتقدمة (Sysmon)
24	7.13.2 المناقشة
26	الفصل الثالث
27	3. تمهيد
27	1.3 منهجية البحث والمتغيرات
27	1.1.3 مراحل المنهجية المتبعة
29	2.1.3 فروض البحث والمتغيرات
29	2.3 بيئة البحث والأدوات المستخدمة
30	1.2.3 قائمة الأدوات والإصدارات
31	3.3 التصميم المعماري للنظام
33	4.3 منطق سير العمل والأتمتة
34	1.4.3 استقبال التنبيه
35	2.4.3 توحيد البيانات واستخراج المؤشرات
35	3.4.3 منطق الفرز والقرار

35	4.4.3 إنشاء القضية والإثراء
36	الفصل الرابع.....
37	4. تمهيد
37	1.4 تنفيذ النظام.....
38	1.1.4 إعداد Wazuh.....
39	2.1.4 إعداد n8n.....
40	3.1.4 إعداد منصة إدارة الحوادث (TheHive)
41	4.1.4 إعداد محرك التحليل الآلي (Cortex).....
42	5.1.4 إعداد منصة استخبارات التهديدات (MISP).....
43	6.1.4 تحديات التنفيذ والحلول التقنية.....
44	2.4 سيناريوهات الاختبار والتحقق العملي
	1.2.4 السيناريو الأول: تنفيذ أمر PowerShell يحتوي على URL لمحاكاة سلوك تحميل ملف أو تنفيذ عن بُعد
45	
45	2.2.4 السيناريو الثاني: التحقق من اتصال شبكي (TCP) يعتمد على IP مشبوه.....
46	3.2.4 السيناريو الثالث: الكشف عن نطاق ضار من خلال استعلام DNS
46	4.2.4 السيناريو الرابع: تحليل قيم التجزئة (Hash Detection) باستخدام FIM
47	3.4 قياس الأداء ومؤشراته.....
47	1.3.4 قياس زمن الاكتشاف الآلي (Automated Mean Time To Detect - MTTD)
48	2.3.4 قياس زمن الاستجابة الآلي (Automated Mean Time To Respond - MTTR)
49	4.4 النتائج والمناقشة.....
49	1.4.4 نتائج القياس الزمني
49	2.4.4 السيناريو الأول: تنفيذ سكريبت (PowerShell (URL)
50	3.4.4 السيناريو الثاني: اتصال TCP بعنوان IP مشبوه
50	4.4.4 السيناريو الثالث: استعلام DNS (Domain)
51	5.4.4 السيناريو الرابع: مراقبة سلامة الملفات FIM (Hash)

52	6.4.4 موثوقية النتائج.....
53	الفصل الخامس.....
54	5. الخلاصة.....
54	1.5 التوصيات العملية.....
55	2.5 حدود الدراسة وإمكانية تعميم النتائج.....
56	3.5 آفاق التطوير.....
58	الفصل السادس.....
59	المراجع.....
62	الفصل السابع.....
63	الملاحق.....

فهرس الأشكال

رقم الشكل	عنوان الشكل	رقم الصفحة
1.2	البنية المعمارية لأداة Wazuh	12
1.3	منهجية البحث	27
2.3	تصميم بنية النظام المقترح وفق نموذج الطبقات	31
3.3	حركة البيانات داخل معمارية النظام	33
4.3	مخطط انسيابي لمنطق سير العمل من الاستقبال إلى الإنشاء	34
1.4	تفاصيل البيئة الافتراضية	37
2.4	الأنظمة المثبتة والمهياة داخل بيئة Docker	38
3.4	تنشيت الوكلاء في برنامج wazuh	38
4.4	سير العمل (Workflow) في n8n	40
5.4	واجهة TheHive تظهر تنبيهاً أمنياً تم إنشاؤه آلياً مع الملاحظات (Observables) المرفقة	41
6.4	واجهة محرك Cortex تظهر نتائج الإثراء الآلي لمؤشر اختراق (Domain (Observable	42
7.4	واجهة MISP تعرض التهديدات المحدثة لاستخدامها في الفرز الأولي	43

فهرس الجداول

رقم الجدول	عنوان الجدول	رقم الصفحة
1.2	أنواع مراكز العمليات الأمنية	11
2.2	مقارنة حلول SIEM التجارية والمفتوحة	12
3.2	مقارنة حلول SOAR التجارية و المفتوحة	13
4.2	مقارنة بين المعالجة اليدوية والمعالجة الآلية	21
1.3	قائمة الأدوات والإصدارات المستخدمة	30
1.4	متوسط القيم الزمنية والنطاق لمؤشري MTDD و MTTR لكل سيناريو اختبار	49

قائمة الاختصارات

الاختصار	المعنى بالإنجليزية	المعنى بالعربية
AbuseIPDB	IP Abuse Database (IP Reputation Database)	قاعدة بيانات سمعة عناوين IP الضارة
API	Application Programming Interface	واجهة برمجة التطبيقات
APT	Advanced Persistent Threat	التهديدات المتقدمة المستمرة
CMD	Windows Command Prompt	موجه أوامر ويندوز
C2	Command and Control Server	خادم القيادة والتحكم
CIA	Confidentiality, Integrity, Availability	السرية، السلامة، التوافر
DNS	Domain Name System	نظام أسماء النطاقات
EDR	Endpoint Detection and Response	كشف واستجابة الأجهزة الطرفية
ELK	Elasticsearch, Logstash, Kibana	Kibana، Logstash، Elasticsearch
FIM	File Integrity Monitoring	مراقبة سلامة الملفات
HIDS	Host-based Intrusion Detection System	نظام كشف التسلل المعتمد على المضيف
HTTP/HTTPS	Hypertext Transfer Protocol / Hypertext Transfer Protocol Secure	بروتوكول نقل النص التشعبي / بروتوكول نقل النص التشعبي الآمن
IOC	Indicator of Compromise	مؤشر الاختراق
IDS	Intrusion Detection System	نظام كشف التسلل
IP	Internet Protocol	بروتوكول الإنترنت
IR	Incident Response	الاستجابة للحوادث
JSON	JavaScript Object Notation	صيغة ترميز كائنات جافا سكريبت
MISP	Malware Information Sharing Platform	منصة مشاركة معلومات البرمجيات الخبيثة

الاختصار	المعنى بالإنجليزية	المعنى بالعربية
MSSP	Managed Security Service Provider	مزود خدمات الأمن المُدار
MTTD	Mean Time to Detect	متوسط وقت الاكتشاف
MTTR	Mean Time to Respond	متوسط وقت الاستجابة
OSINT	Open Source Intelligence	استخبارات المصادر المفتوحة
OTX	Open Threat Exchange	تبادل التهديدات المفتوح
REST	Representational State Transfer	نقل الحالة التمثيلي
SIEM	Security Information and Event Management	إدارة معلومات وأحداث الأمن
SIRP	Security Incident Response Platform	منصة الاستجابة للحوادث الأمنية
SOAR	Security Orchestration, Automation, and Response	التنسيق والأتمتة والاستجابة الأمنية
SOC	Security Operations Center	مركز العمليات الأمنية
SSH	Secure Shell	شل آمن
STIX/TAXII	Structured Threat Information Expression / Trusted Automated eXchange of Intelligence Information	لغة التعبير المنظم عن معلومات التهديدات / التبادل الآلي الموثوق لمعلومات مؤشرات التهديدات
Sysmon	System Monitor	مراقب النظام
TIP	Threat Intelligence Platform	منصة استخبارات التهديدات
TTP	Tactics, Techniques, and Procedures	التكتيكات والتقنيات والإجراءات
UEBA	User and Entity Behavior Analytics	تحليل سلوك المستخدم والكيان
URL	Uniform Resource Locator	محدد موقع الموارد الموحد

المخلص

يواجه المشهد الرقمي تصاعداً في تعقيد الهجمات السيبرانية، مما يتقل كاهل مراكز العمليات الأمنية بظاهرة "إرهاق التنبهات" الناجمة عن تدفق الإنذارات بكثرة، إلى جانب بطء المعالجة اليدوية لمؤشرات الاختراق المتمثلة في (IP, URL, Domain, Hashes)، وهو ما يستنزف الموارد ويرفع التكاليف، مما يفرض ضرورة ملحة لتحسين كفاءة الكشف والاستجابة وتقليل التدخل البشري بأقل تكلفة تشغيلية.

ولتحقيق ذلك، تم في هذا البحث تصميم معمارية أتمتة أمنية مفتوحة المصدر بالكامل، لأتمتة دورة حياة مؤشرات الاختراق بدءاً من التجميع والتحليل حتى توثيقها كقضايا أمنية مثارة. كما تم استخدام المنهج التجريبي التطبيقي من خلال بناء بيئة افتراضية معزولة تحاكي مركز عمليات أمني حديث، حيث نُشرت المكونات بحاويات Docker وتكاملت عبر محرك الأتمتة (n8n)، وسُجلت أحداث نقاط النهاية عبر Sysmon.

أظهرت النتائج أتمتةً كاملة لدورة معالجة التهديدات في البيئة المختبرية المعزولة، بمتوسط زمن اكتشاف آلي تراوح بين 3.28 و6.26 ثانية، ومتوسط زمن استجابة تراوح بين 10.79 و19.04 ثانية. وقد صُممت آليات الفرز الاستباقي لتصفية الإنذارات كاذبة، مما يخفّف العبء عن المحللين، فضلاً عن قابلية المعمارية للتوسع لتلائم المؤسسات الصغيرة والمتوسطة والقطاعات التعليمية.

Abstract

The digital landscape is witnessing a rapid escalation in the complexity of cyberattacks, burdening Security Operations Centers (SOCs) with the phenomenon of "alert fatigue" caused by the overwhelming influx of alerts and high false positive rates, alongside the slow manual processing of Indicators of Compromise (IOCs) — namely IP addresses, URLs, domains, and file hashes. This operational burden drains resources and increases costs, creating an urgent need to improve detection and response efficiency while minimizing human intervention at a reduced operational cost.

To address this, a fully open-source security automation architecture was designed to automate the complete IOC lifecycle, from collection and analysis through to documentation as enriched security cases. An experimental applied methodology was adopted by constructing an isolated virtual environment simulating a modern SOC, where components were deployed via Docker containers, integrated through the n8n automation engine, and endpoint events were captured using Sysmon.

Results demonstrated full automation of the threat processing cycle within the isolated lab environment, achieving an automated Mean Time to Detect (MTTD) ranging from 3.28 to 6.26 seconds, and a Mean Time to Respond (MTTR) ranging from 10.79 to 19.04 seconds. Proactive triage mechanisms were designed to filter false positives, thereby reducing the analytical burden on security analysts. The architecture further demonstrated scalability suitable for small and medium-sized enterprises as well as educational institutions.

الفصل الأول

المقدمة

1. المقدمة

في ظل التطور المتسارع للمشهد الرقمي وتزايد الاعتماد على البنى التحتية التكنولوجية، تواجه المؤسسات تحديات أمنية غير مسبقة تتمثل في تصاعد الهجمات السيبرانية تعقيداً وانتشاراً [1]، حيث أصبحت القدرة على الكشف السريع والاستجابة الفعالة للتهديدات أمراً حيوياً للحفاظ على سلامة الأصول الرقمية واستمرارية الأعمال. في هذا السياق، تلعب مراكز العمليات الأمنية (Security Operations Centers – SOC) دوراً محورياً في المراقبة المستمرة، وتحليل الأحداث الأمنية، وإدارة الحوادث [2]. تعتمد هذه المراكز بشكل أساسي على أنظمة إدارة معلومات وأحداث الأمن (Security Information and Event Management - SIEM) لجمع وتحليل البيانات الأمنية، حيث تُعد منصة Wazuh مفتوحة المصدر مثلاً بارزاً على هذه الأنظمة، بقدرتها على رصد نقاط النهاية وتوليد تنبيهات حول الأنشطة المشبوهة [3].

على الرغم من أن هذه القدرة على المراقبة وتوليد التنبيهات تفرض على مراكز العمليات الأمنية التقليدية تحديات تشغيلية بالغة، من أبرزها الكم الهائل من الإنذارات اليومية والارتفاع الملحوظ في معدلات الإنذارات الكاذبة، ويؤدي هذا التدفق إلى ظاهرة تُعرف بـ "إرهاق التنبيهات" (Alert Fatigue)، وهي حالة تزيد من الضغط على المحللين الأمنيين وتحد من تركيزهم، مما يعيق قدرتهم على تمييز التهديدات الفعلية والاستجابة لها بالسرعة المطلوبة [4]. علاوة على ذلك، تُشكل المعالجة اليدوية عبئاً زمنياً كبيراً على المحللين. إذ تمر عملية التحقيق بسلسلة طويلة من الخطوات تبدأ باستخراج مؤشرات الاختراق (Indicators of Compromise – IOCs) والتحقق منها، ثم إثرائها عبر مصادر استخبارات التهديدات، وتنتهي بتوثيقها وفتح قضايا الاستجابة. هذا الاعتماد الكبير على التدخل البشري يؤدي إلى إطالة "متوسط وقت الاكتشاف" (Mean Time to Detect - MTTD) و"متوسط وقت الاستجابة" (Mean Time to Respond - MTTR)، مما يمنح المهاجمين نافذة زمنية أطول لتحقيق أهدافهم [5]. لمواجهة هذه التحديات، برزت الأتمتة كركيزة أساسية لتعزيز مرونة وكفاءة مراكز العمليات الأمنية.

يهدف هذا البحث إلى تصميم وتنفيذ نظام أتمتة أمني متكامل ومنخفض التكلفة، يعتمد كلياً على مجموعة من الأدوات مفتوحة المصدر. يركز النظام على أتمتة عملية معالجة مؤشرات الاختراق (IOCs) المستخرجة من التنبيهات الأمنية، لا سيما تلك الناتجة عن تنفيذ سكريبتات، والتي غالباً ما تشير إلى أنشطة خبيثة. تتكون البنية المقترحة من مكونات رئيسية تشمل Wazuh للكشف والرصد بما في ذلك مراقبة سلامة الملفات (File Integrity Monitoring - FIM) [3]، [6]، و n8n للأتمتة وتنسيق سير العمل [7]،

و TheHive لإدارة الحوادث[8]، ولتحليل مؤشرات الاختراق، يعتمد النظام على منصة Cortex التي تتكامل مع محركات الإثراء الخارجي مثل VirusTotal و AbuseIPDB - Abuse IP DataBase و AlienVault Open Threat Exchange - OTX ، بالتزامن مع الربط بمنصة (MISP - Malware Information Sharing Platform) لتوفير استخبارات التهديدات (Threat Intelligence) ومقارنتها بقواعد البيانات المحلية [1]، [9].

1.1 مشكلة البحث

تواجه مراكز العمليات الأمنية (SOCs) أعباءً تشغيلية ضخمة بسبب كثافة البيانات وتعدد أنظمة المراقبة. يمكن تركيز المشكلة البحثية في المحاور الرئيسية الآتية:

1. تراكم التنبيهات الأمنية (Alert Fatigue): الارتفاع في حجم الإنذارات يجعل عملية الفرز اليدوي واستبعاد الإنذارات الكاذبة (False Positives) مهمة معقدة وعرضة للأخطاء البشرية.
2. استهلاك الوقت والجهد: هدر الموارد البشرية و الوقت في العمليات اليدوية لتحليل مؤشرات الاختراق.
3. التحديات الاقتصادية: العبء المالي الكبير المترتب على اقتناء منصات الأتمتة التجارية.

2.1 أسئلة البحث

1. كيف يساهم النظام المقترح في تقليل التنبيهات المتراكمة ومعالجتها وتخفيف الجهد المرتبط بتحليلها؟
2. ما مدى فعالية دمج مصادر الإثراء والتحليل في خفض الوقت والجهد المستغرق في التحقيق اليدوي؟
3. هل يمكن بناء معمارية أتمتة واستجابة أمنية متكاملة ومنخفضة التكلفة تعتمد كلياً على الحلول مفتوحة المصدر؟

3.1 أهداف البحث

يتمثل الهدف العام لهذا البحث في تصميم وبناء نموذج أتمتة أمني متكامل ومنخفض التكلفة بالاعتماد على أدوات مفتوحة المصدر، بهدف رفع كفاءة مراكز العمليات الأمنية (SOCs) في معالجة التنبيهات وتسريع الاستجابة للحوادث المعتمدة على مؤشرات الاختراق (IOCs) والمحصورة في (IP, Domain, URL, Hashes). وينبثق من هذا الهدف العام مجموعة من الأهداف الفرعية الآتية:

1. أتمتة معالجة التنبيهات عن طريق بناء مسار عمل (Workflow) لفرز التنبيهات الأمنية آلياً، مما يساهم في تقليل الجهد البشري المرتبط بالتعامل مع الإنذارات الكاذبة.
2. تحسين عملية الإثراء والتحقق عبر ربط أنظمة الكشف والمراقبة بمصادر استخبارات التهديدات، بهدف تقليل استهلاك الوقت والجهد المبذول في التحليل اليدوي لمؤشرات الاختراق.
3. تطوير نموذج أتمتة منخفض التكلفة عبر دمج واستخدام الحلول البرمجية مفتوحة المصدر لتقديم بديل عملي وفعال يغني عن تبني الأنظمة التجارية باهظة الثمن.

4.1 أهمية البحث

تكمن أهمية هذا البحث في سعيه لتقديم حلول تطبيقية للتحديات التشغيلية التي تواجه مراكز العمليات الأمنية (SOCs). وتبرز هذه الأهمية في قدرة النموذج المقترح على تقليل الجهد اليدوي في معالجة التنبيهات الأمنية وفرزها، مما يساهم بشكل مباشر في تحسين سرعة وكفاءة الاستجابة الأولية للتهديدات، ويقلص الوقت المتاح للمهاجمين لإحداث أي أضرار بالشبكة.

ومن الناحية التقنية، يُثبت البحث فاعلية التكامل بين منصات الكشف الأمني، وأدوات الإثراء، وأنظمة إدارة الحوادث، لتعمل معاً كمنظومة آلية واحدة ومتراصة. وإلى جانب ذلك، يحمل البحث قيمة اقتصادية، إذ يوفر حلاً عملياً للمؤسسات والقطاعات المختلفة بتقديم بديل فعال بالاعتماد على أدوات مفتوحة المصدر يغنيها عن الأعباء المالية للأنظمة التجارية الباهظة.

5.1 حدود البحث

نظراً لطبيعة البحث والقيود الزمنية والتقنية، تم وضع مجموعة من الحدود لضمان تركيز الدراسة وتحقيق أهدافها بدقة، وتتمثل هذه الحدود في الآتي:

- يركز البحث على الأتمتة الجزئية لبعض وظائف مركز العمليات الأمنية (SOC)، المتمثلة تحديداً في عمليات الكشف المبدئي، والفرز التلقائي (Triage)، واستخراج بعض مؤشرات الاختراق (IOCs) وإثرائها، وصولاً إلى الإنشاء الآلي للقضايا الأمنية، دون التدخل في المهام الإدارية الأخرى للمركز.
- يقتصر النطاق الفني على توظيف ودمج مجموعة محددة من الأدوات مفتوحة المصدر، وتشمل: منصة (Wazuh) للمراقبة والكشف، ومحرك (n8n) لتنسيق الأتمتة، ومنصتي (TheHive و Cortex) لإدارة الحوادث والتحليل، إلى جانب (AbuseIPDB - OTX - MISP - VirusTotal) كمنصات لاستخبارات التهديدات، وأداة (Sysmon) لجمع الأحداث الطرفية.
- اقتصر تنفيذ وتقييم المنظومة المقترحة على بيئة محاكاة افتراضية معزولة ومضبوطة، ولم تُختبر في بيئة تشغيلية حقيقية. فضلاً عن ذلك، لم تُجر مقارنة تجريبية مباشرة مع المعالجة اليدوية ضمن نفس البيئة؛ إذ تستند المقارنة مع الأساليب اليدوية إلى أوقات مرجعية مُستقاة من الأدبيات السابقة لا إلى قياسات ميدانية موازية (Production Environment) [5].
- حدود موضوعية (سيناريوهات الاختبار): يقتصر تقييم النظام على محاكاة سيناريوهات هجومية محددة ترتبط باكتشاف نصوص برمجية (Scripts) أو اتصالات شبكية مشبوهة، بالاعتماد الكلي على مؤشرات الاختراق التقنية (Internet Protocol - IP, Domain, Uniform Resource Locator - URL, Hashes)، ولا يتطرق البحث إلى الكشف القائم على التحليل السلوكي المتقدم (Behavioral Analysis).

6.1 منهجية البحث

اعتمدت هذه الدراسة على المنهجية التجريبية التطبيقية لبناء وتقييم نموذج عملي لأتمتة العمليات الأمنية باستخدام أدوات مفتوحة المصدر. ويرجع ذلك إلى أن التقييم الدقيق لأنظمة الأتمتة يتطلب محاكاة بيئة تشغيلية واقعية لقياس الأداء والفوارق الزمنية بدقة [6]. واستناداً إلى هذه المنهجية، جرى تنفيذ خطوات البحث عبر خمس مراحل متسلسلة:

1. **الدراسة النظرية وتحليل المتطلبات:** وتضمنت استعراض الأدبيات السابقة، وتحليل المتطلبات

الوظيفية وغير الوظيفية للنظام.

2. **تصميم المعمارية:** شملت هذه المرحلة تصميم نظام متكامل من أربع طبقات وظيفية (المراقبة، الأتمتة، الإثراء الاستخباراتي، إدارة الحوادث).

3. **بناء البيئة المختبرية وتنفيذ النظام:** باستخدام تقنيات المحاكاة والحاويات، وتطوير سير عمل آلي يربط مكونات النظام عبر بروتوكولات تكامل قياسية.

4. **الاختبار والتقييم العملي:** من خلال محاكاة سيناريوهات هجومية واقعية، وقياس مؤشرات الأداء الرئيسية مثل متوسط وقت الاكتشاف ومتوسط وقت الاستجابة.

5. **تحليل النتائج والتوثيق:** لتقييم مدى نجاح النظام في تحقيق أهداف البحث.

وسيتناول الفصل الثالث التفاصيل الكاملة للمنهجية، بما في ذلك مواصفات البيئة التقنية، والإصدارات الدقيقة للأدوات، وإعدادات التكوين، وإجراءات القياس.

7.1 هيكلية البحث

تم تقسيم هذا البحث إلى ستة فصول رئيسية، وذلك على النحو الآتي :

• الفصل الأول: المقدمة

يستعرض التمهيد، ومشكلة الدراسة، وأهدافها، وأسئلتها، وأهميتها التطبيقية، وحدودها الفنية والموضوعية، مع نبذة مختصرة عن المنهجية المتبعة.

• الفصل الثاني: الإطار النظري والدراسات السابقة

يتناول مفاهيم الأمن السيبراني، والـ SOC، وأنظمة SIEM و SOAR، وبروتوكولات التكامل البرمجي، مستعرضاً الدراسات السابقة لتحديد الفجوة العلمية.

- **الفصل الثالث: منهجية البحث وتصميم النظام**

يشرح المنهج التجريبي التطبيقي ومواصفات بيئة الاختبار، مستعرضاً المخططات الهندسية للتصميم المعماري الطبقي ومنطق سير العمل الآلي.

- **الفصل الرابع: التنفيذ والنتائج**

يوثق بناء بيئة الحاويات الافتراضية، وإعداد الأدوات، وتنفيذ سيناريوهات التحقق العملي، مع تحليل نتائج القياس الزمني لمؤشري MTTR و MTDD.

- **الفصل الخامس: الخلاصات والتوصيات**

يقدم الاستنتاجات الختامية، والتوصيات العملية للمؤسسات والقطاع التعليمي، مع تحديد حدود الدراسة الحالية وآفاق تطويرها المستقبلي.

- **الفصل السادس: المراجع**

يتضمن قائمة شاملة بجميع المصادر والمراجع العلمية التي استُند إليها في إعداد هذا البحث، مرتبةً وفق نظام التوثيق المعتمد.

الفصل الثاني

الإطار النظري والدراسات السابقة

2. تمهيد

يستعرض هذا الفصل الأسس النظرية والمفاهيم العلمية التي يركز عليها بناء نموذج أتمتة العمليات الأمنية (SOC Automation)، حيث يُعد الفهم العميق لهذه الأسس منطلقاً ضرورياً لاستيعاب كيفية معالجة التحديات الأمنية المعاصرة. ينطلق الفصل بالتركيز على مفهوم الأمن السيبراني والتحديات التي فرضها التطور النوعي في أساليب الهجمات، وصولاً إلى الدور المحوري لمركز العمليات الأمنية (SOC) كخط دفاع أول للمؤسسات.

كما يتناول الفصل تحليل التقنيات المكونة للنموذج والتدقيق فيها، بدءاً من أنظمة إدارة المعلومات والأحداث الأمنية متمثلة في منصة Wazuh، مروراً بتقنيات التنسيق والأتمتة عبر منصة n8n، وصولاً إلى استخبارات التهديدات ومنصات إدارة القضايا الأمنية (TheHive & Cortex). ويركز هذا الإطار النظري على إيضاح آليات التكامل البرمجي بين هذه الأدوات مفتوحة المصدر، وكيفية توظيف مؤشرات الاختراق وسجلات المراقبة المجهريّة لتحويل العمليات اليدوية التقليدية إلى مسارات عمل آلية سريعة. وفي ختام الفصل، سيتم استعراض ومناقشة أهم الدراسات السابقة التي تناولت هذا المجال، وذلك لتحديد الموقف العلمي للبحث الجاري وسد الفجوات التي لم تتطرق إليها الأبحاث السابقة.

1.2 الأمن السيبراني

1.1.2 مفهوم الأمن السيبراني وأهميته

الأمن السيبراني هو مجموعة الممارسات، والتقنيات، والبروتوكولات المصممة لحماية البنى التحتية والبيانات من الوصول غير المصرح به أو التخريب. يركز هذا المفهوم على حماية ما يُعرف بـ "مثلث الأمان" (Confidentiality, Integrity, Availability - CIA Triad)، والذي يشمل [10]:

- السرية (Confidentiality): حصر الوصول للبيانات للمصرح لهم فقط.
- السلامة (Integrity): منع العبث بالبيانات أو تعديلها من جهات غير مخولة.
- التوافر (Availability): ضمان استمرارية عمل الأنظمة دون انقطاع.

2.1.2 التحديات الأمنية المعاصرة

تواجه فرق الأمن اليوم طيفاً واسعاً من التحديات التقنية والإدارية، أبرزها:

- التهديدات المتقدمة المستمرة (Advanced Persistent Threat - APTs): التسلل الهادئ لشبكة الضحية والتخفي بداخلها لشهور طويلة لسرقة البيانات[10].
- برمجيات الفدية (Ransomware): تشفير الأصول الرقمية للمؤسسات وابتزازها مالياً، مع التهديد بتسريب البيانات (الابتزاز المزدوج)[11].
- إرهاق التنبيهات (Alert Fatigue): كثرة التنبيهات الكاذبة التي تشتت المحلل عن التهديدات الحقيقية[4].
- نقص الكوادر المتخصصة: النقص العالمي في الخبراء القادرين على تحليل البيانات الأمنية المعقدة [10].

3.1.2 آليات المواجهة (الدفاع في العمق)

للتصدي لهذه التحديات، تتبنى المؤسسات استراتيجية "الدفاع في العمق" (Defense in Depth). تعتمد هذه الاستراتيجية على نشر طبقات أمنية متعددة ومستقلة، فإذا تجاوز المهاجم جدار الحماية (Firewall)، سيصطدم بنظام كشف التسلل (Intrusion Detection System - IDS)، ثم ببرامج حماية نقاط النهاية (Endpoint Detection and Response - EDR). هذا التعدد يولد ملايين السجلات يومياً، مما استوجب إنشاء مركز قيادة موحد لجمعها وتحليلها وهو (SOC)[2].

2.2 مركز العمليات الأمنية (Security Operation Center – SOC)

1.2.2 المفهوم والمكونات

مركز العمليات الأمنية (SOC) هو الوحدة المركزية والعصب الرئيسي لأمن المعلومات داخل المؤسسة. يعمل على مدار الساعة (24/7) للمراقبة والكشف والاستجابة [2]. يعتمد الـ SOC على ثلاثة ركائز أساسية [12], [13]:

- الأشخاص (People): المحللون، صائدو التهديدات، والمستجيبون للحوادث.
- العمليات (Processes): كتيبات الاستجابة (Playbooks) والإجراءات القياسية للتعامل مع التهديدات.

- التقنيات (Technology): الأدوات والمنصات (مثل SIEM و SOAR) التي تنفذ العمليات آلياً ويدوياً.

2.2.2 أنواع مراكز العمليات الأمنية

تختلف مراكز العمليات بناءً على حجم المؤسسة وميزانيتها، ويلخص الجدول التالي أبرز أنواعها [2], [12]:

جدول (1.2) أنواع مراكز العمليات الأمنية

نوع الـ SOC	الوصف	المزايا	العيوب
الداخلي (In-house)	يُننى ويُدار بالكامل داخل المؤسسة وبواسطة موظفيها.	تحكم كامل، سرية تامة، تخصيص عالٍ.	تكلفة تأسيس وتشغيل باهظة جداً.
المُعدّل (MSSP)	تُعهد خدمات المركز إلى مزود خارجي متخصص.	تكلفة أقل، خبرات متقدمة فورية.	فقدان التحكم الكامل بالبيانات.
الهجين (Hybrid)	يجمع بين فريق داخلي للحوادث الحرجة ومزود خارجي للمراقبة.	توازن مثالي بين التكلفة والتحكم.	يتطلب تنسيقاً إدارياً عالياً.
الافتراضي (Virtual)	فريق لامركزي يعمل عن بُعد باستخدام تقنيات سحابية.	مرونة عالية وتقليل تكاليف البنية التحتية.	تحديات في التواصل والتنسيق السريع.

3.2 أنظمة إدارة المعلومات والأحداث الأمنية (Security Information and Event Management - SIEM)

نظام (SIEM) هو النواة الأساسية لمركز العمليات. يقوم بجمع السجلات (Logs) من آلاف الأجهزة، ويوحد صيغتها (Normalization)، ثم يبحث عن العلاقات المنطقية بينها (Correlation) ليقيم بإصدار تنبيهات (Alerts) للمحللين عند رصد سلوك مشبوه [12].

يتعامل النظام مع مسارين لاكتشاف التهديدات [14]:

- أحداث مستندة إلى مؤشرات الاختراق (IOC-based Events): تُبنى على مطابقة السجلات الواردة مع تهديدات معروفة مسبقاً (مثل عنوان IP خبيث أو تجزئة ملف ضار).
- أحداث مستندة إلى السلوك (Behavioral Events): تعتمد على تحليل سلوك المستخدم أو النظام (User and Entity Behavior Analytics - UEBA). التنبيه هنا يصدر عند حدوث انحراف حاد عن السلوك الطبيعي (مثل تسجيل الدخول من دولة مختلفة فجأة)

ينقسم سوق أدوات SIEM إلى فئتين، يوضحهما الجدول الآتي [12], [14]:

جدول (2.2) مقارنة حلول SIEM التجارية والمفتوحة

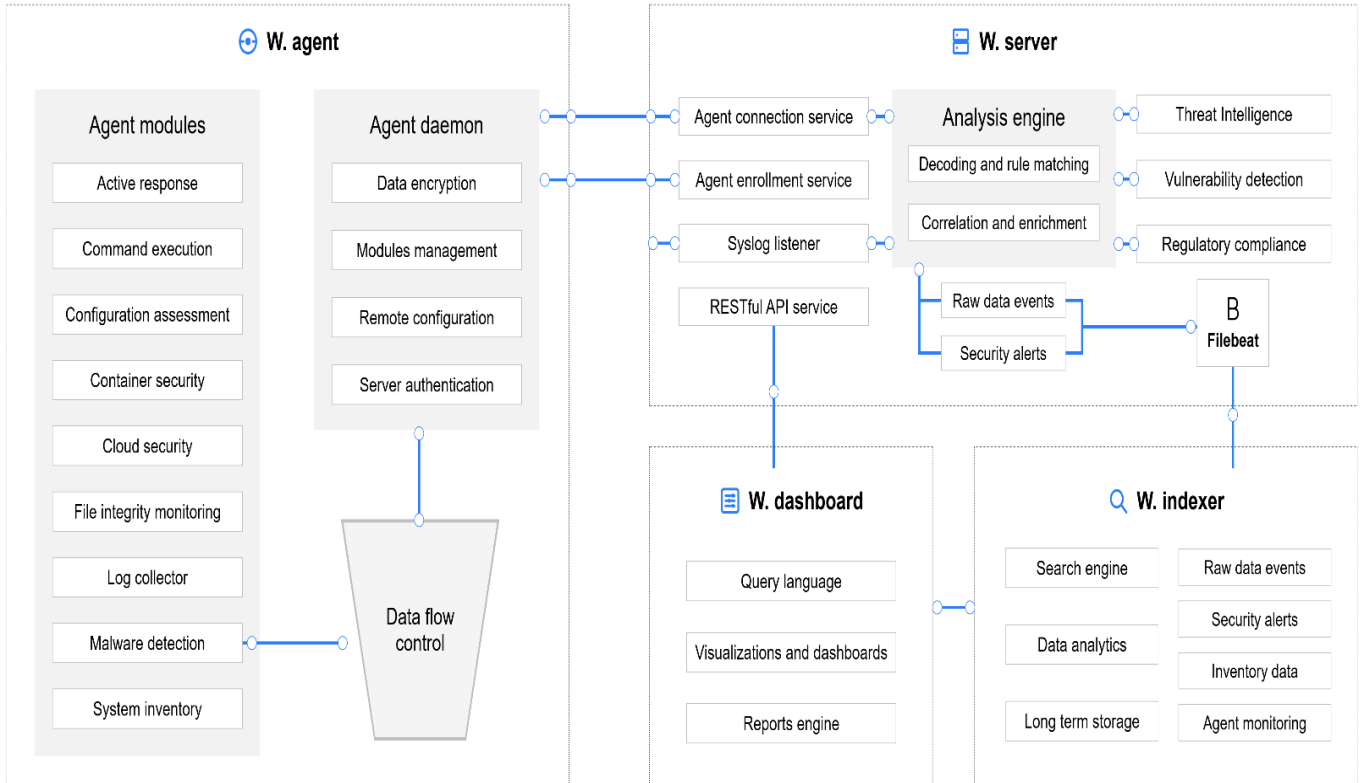
معايير المقارنة	أنظمة SIEM التجارية	أنظمة SIEM مفتوحة المصدر
التكلفة	باهظة (تُسعر بناءً على حجم البيانات GB/Day).	مجانية (تكلفة التشغيل والصيانة فقط).
المرونة	مقيدة بما تتيحه الشركة.	عالية جداً، قابلة للتعديل والبرمجة.
الدعم الفني	دعم احترافي مخصص (7/24).	يعتمد على دعم المجتمع والمنتديات.
أمثلة بارزة	Splunk, IBM QRadar	Wazuh, Elastic Stack (ELK)

1.3.2 منصة Wazuh

في هذا البحث تم اعتماد Wazuh كمنصة أمنية متكاملة توفر قدرات (SIEM) بالإضافة إلى كشف التسلل (Host-based Intrusion Detection System - HIDS) وميزة مراقبة سلامة الملفات FIM، تُنفَّذ وظيفة FIM داخلياً عبر وحدة Syscheck المدمجة في Wazuh، والتي تعمل على حساب قيم التجزئة (Hashes) للملفات الحساسة ومقارنتها دورياً لرصد أي تغيير غير مصرح به، مما يوفر رؤية عميقة دون تكاليف ترخيص [3], [15].

Endpoint security agent

Central components



الشكل (1.2) البنية المعمارية لأداة Wazuh [6].

4.2 التنسيق والأتمتة والاستجابة الأمنية (Security Orchestration, Automation, and Response - SOAR)

ظهرت منصات (SOAR) لحل أزمة "إرهاق التنبيهات". حيث تهدف هذه التقنية إلى ربط الأدوات الأمنية المختلفة لتعمل معاً، وتنفيذ المهام الروتينية المتكررة بشكل آلي تماماً عبر كتيبات الاستجابة (Playbooks)، مما يحول التنبيه إلى "قضية مُثارة" في ثوانٍ معدودة [13], [15].

ينقسم سوق أدوات SOAR إلى فئتين، يوضحهما الجدول الآتي [12], [15]:

جدول (3.2) مقارنة حلول SOAR التجارية و المفتوحة

الميزة	حلول SOAR التجارية	حلول SOAR مفتوحة المصدر
التكلفة	تكلفة ترخيص عالية.	مجانية أو منخفضة التكلفة.
المرونة والتخصيص	محدودة، تعتمد على التكاملات التي يوفرها المزود.	عالية جداً، يمكن تعديلها لتناسب أي بيئة.
الدعم الفني	دعم فني احترافي.	يعتمد على المجتمع (Community Support).
التكاملات الجاهزة	مكتبة واسعة من التكاملات الجاهزة مع الأدوات الأمنية الشائعة.	قد تكون محدودة، وتتطلب جهداً إضافياً.
أمثلة	Palo Alto XSOAR, Splunk SOAR, IBM Resilient	n8n, Shuffle, Demisto Community Edition

1.4.2 منصة n8n

تم اعتماد منصة n8n في هذه المعمارية لتقوم بدور محرك التنسيق والأتمتة، وذلك نظراً لتمييزها بقدرات "التنسيق الشرطي" (Conditional Orchestration). إذ لا يقتصر دور المنصة على مجرد نقل البيانات بين الأنظمة الأمنية المختلفة، بل يتجاوز ذلك لتطبيق منطق برمجي دقيق يعتمد على شروط مسبقة التحديد (مثل مستوى الخطورة أو اكتشاف مؤشرات اختراق). وتتيح هذه الميزة التوجيه الذكي للتنبيهات نحو المسارات الصحيحة ضمن سير العمل (Workflow)، كأن يتم تصعيد التنبيه لإنشاء تنبيه في منصة TheHive عند تحقق شروط الخطورة، أو إيقاف المعالجة وتجاهل التنبيه خلاف ذلك [13], [15].

5.2 الاستجابة للحوادث (Incident Response - IR)

1.5.2 دورة حياة الاستجابة

الاستجابة للحوادث (Incident Response - IR) هي المنهجية المتبعة للسيطرة على الاختراق. حيث تمر بعدة مراحل متسلسلة [8]:

- التحضير (Preparation): تجهيز الأدوات والفرق.
- الاكتشاف والتحليل (Detection & Analysis): رصد التهديد وتحديد نطاقه.
- الاحتواء (Containment): عزل الأجهزة المصابة لمنع انتشار الضرر.
- الاستئصال (Eradication): حذف البرمجيات الخبيثة.
- التعافي (Recovery): إعادة تشغيل الأنظمة بأمان.
- الدروس المستفادة (Lessons Learned): تحديث السياسات لتجنب تكرار الحادث.

2.5.2 منصات إدارة القضايا (Case Management Platforms)

تُمثل منصات إدارة القضايا (Case Management Platforms) أنظمة برمجية متخصصة صُممت لتنظيم وتتبع الحوادث والملفات بشكل مركزي ومنهجي. وعلى الرغم من استخداماتها الواسعة في قطاعات إدارية متعددة، إلا أنها تكتسب أهمية محورية داخل مراكز العمليات الأمنية (SOC) ؛ حيث تُعد الركيزة الأساسية لإدارة سير عمل الاستجابة للحوادث، وتوثيق الأدلة الرقمية، وتنسيق جهود المحللين الأمنيين.

ومن أبرز الأدوات مفتوحة المصدر التي تُستخدم بكفاءة عالية في هذا السياق: [8]

- منصة TheHive: هي نظام إدارة قضايا (Case Management) مفتوح المصدر مصمم للـ SOC [16]. يتيح للمحللين فتح القضايا، توزيع المهام، وتوثيق الأدلة.
- محرك Cortex: لا يظهر كواجهة مستقلة غالباً، بل هو "المحرك الخلفي" المقترن بـ TheHive. يستلم Cortex مؤشرات الاختراق من القضية، ويحللها آلياً عبر الاستعلام من عشرات المصادر الخارجية، ثم يعيد التقييم النهائي للقضية فوراً، مما يوفر ساعات من البحث اليدوي [8], [17].

6.2 استخبارات التهديدات

هي معلومات مدعومة بالسياق لمساعدة المؤسسة على اتخاذ قرارات دفاعية. تنقسم إلى [9]:

- استراتيجية: تركز على دوافع المهاجمين (للإدارة العليا).
- تكتيكية: تركز على أساليب وتقنيات المهاجمين (Tactics, Techniques, and Procedures - TTPs).
- تشغيلية: تحذيرات حول حملات هجومية وشيكة.
- تقنية: بيانات آلية مثل مؤشرات الاختراق (IOCs).

تعتمد مراكز العمليات الأمنية (SOCs) بشكل جوهري على منصات استخبارات التهديدات (Threat Intelligence Platforms – TIPs) لتعزيز قدراتها الدفاعية. ومن أبرز هذه المنصات والأدوات:

- منصة (MISP): منصة رائدة ومفتوحة المصدر، تُستخدم لتخزين ومشاركة معلومات التهديدات على المستويين المحلي والعالمي [18].
- منصة (OpenCTI): منصة مفتوحة المصدر مخصصة لتنظيم المعرفة المتعلقة بالتهديدات وتوحيدها وفق أطر عمل قياسية معتمدة (مثل Structured Threat Information Expression / Trusted Automated eXchange of Intelligence Information - STIX/TAXII).
- محرك (VirusTotal): أداة فحص سحابية متقدمة تعمل على تحليل الملفات والروابط المشبوهة عبر عرضها على أكثر من 70 محركاً لمكافحة الفيروسات في آنٍ واحد [10].
- شبكة (AlienVault OTX): شبكة مجتمعية مفتوحة تعتمد على مبدأ التعهيد الجماعي (Crowdsourcing) لمشاركة حزم التهديدات (Pulses) وتحديثاتها المستمرة.
- منصة (AbuseIPDB): قاعدة بيانات متخصصة في تقييم سمعة عناوين الإنترنت (IPs)، ويتم توظيفها في سير العمل عبر (n8n) للتحقق الآلي من درجة خطورة العنوان من خلال واجهات (Application Programming Interface - APIs) قبل تصعيد التنبيه [17].

1.6.2 منصة (Malware Information Sharing Platform - MISP)

وتجدر الإشارة إلى أن منصة MISP تُمثل حجر الزاوية في المعمارية المقترحة لهذا البحث، إذ تم اعتمادها كمصدر أساسي لاستخبارات المصادر المفتوحة (Open Source Intelligence - OSINT). وتقوم المنصة بجلب مصادر بيانات التهديدات (Threat Feeds) من مجتمعات أمنية متعددة ومزامنتها آلياً، مما يضمن التوفر الدائم لأحدث مؤشرات الاختراق (IOCs) لاستخدامها في عمليات الفرز والمطابقة [18].

7.2 تقنية الحاويات البرمجية (Containerization)

في بيئات العمليات الأمنية (SOC) الحديثة، يتطلب بناء معمارية تتكون من عدة أدوات مفتوحة المصدر بنية تحتية مرنة وخفيفة الوزن تضمن عمل هذه الأدوات معاً دون تعارض. وهنا تبرز أهمية تقنية "الحاويات البرمجية" (Containerization) كبديل متطور وفعال للآلات الافتراضية التقليدية (Virtual Machines). وتُعرف الحاويات بأنها بيئات معزولة وخفيفة الوزن تتشارك نفس نواة نظام التشغيل (Operating System - OS Kernel) الخاص بالخدّام المضيف، مما يجعلها أسرع في التشغيل وأقل استهلاكاً لموارد النظام [19].

1.7.2 منصة Docker

اعتمد هذا البحث على تقنية (Docker) وأداة (Docker Compose) كبنية تحتية أساسية لنشر وبناء المعمارية المقترحة. وجاء هذا الاعتماد لتجاوز تعقيدات التنصيب التقليدي وتقادي تعارض المكتبات البرمجية وإصدارات قواعد البيانات بين الأدوات المختلفة مثل (MISP, Cortex, TheHive, n8n). إذ توفر هذه التقنية بيئة تشغيل معزولة لكل أداة، مما يضمن استقرار المنظومة ككل ويُسهّل إجراءات النسخ الاحتياطي. إضافة إلى ذلك، تتيح هذه البنية سرعة نشر أو تفكيك معمارية مركز العمليات الأمنية (SOC) بالكامل، مما يمنح النظام مرونة تشغيلية عالية [19].

8.2 أدوات القياس ومؤشرات الأداء

1.8.2 زمن الاكتشاف الآلي (Automated MTTD)

يعرف بأنه متوسط الوقت المستغرق لاكتشاف التهديد الأمني أو النشاط المشبوه منذ لحظة وقوعه داخل الشبكة أو الأنظمة. وفي سياق البيانات المؤتمتة، يُقصد به الزمن الفاصل بين حدوث الاختراق أو الحدث الأمني، وبين قدرة المنظومة الأمنية على رصده وتوليد تنبيهه مؤكد بشأنه[5].

2.8.2 زمن الاستجابة الآلي (Automated MTTR)

يعرف بأنه متوسط الوقت المستغرق للاستجابة للتهديد الأمني بعد اكتشافه. وفي إطار الأتمتة الأمنية، يُمثل هذا المؤشر الفترة الزمنية الممتدة من لحظة استلام التنبيه الأمني، مروراً بعمليات الفحص وإثراء البيانات، وصولاً إلى توثيق الحادثة وتقديم التقرير النهائي للتحليل[5].

9.2 مؤشرات الاختراق (Indicators of Compromise - IOCs)

مؤشرات الاختراق هي الأدلة الجنائية الرقمية والبصمات التقنية التي يتركها المهاجمون خلفهم بعد أو أثناء اختراق الأنظمة والشبكات. وتُعد هذه المؤشرات حجر الزاوية في عمليات الاكتشاف والاستجابة، حيث تعتمد أنظمة الأتمتة (مثل n8n) ومنصات استخبارات التهديدات (مثل MISP) على استخراجها وتحليلها للتحقق من التهديدات. وفي سياق هذا البحث، تم التركيز على أتمتة دورة حياة أربعة أنواع رئيسية من مؤشرات الاختراق التقنية نظراً لسهولة معالجتها آلياً، وهي [20]:

1. عناوين بروتوكول الإنترنت (IP Addresses): تُستخدم عناوين الـ IP لتحديد مصدر الهجوم الشبكي أو الوجهة التي تتواصل معها البرمجيات الخبيثة، مثل خوادم القيادة والتحكم (Command and Control - C2 Servers). في بيانات الأتمتة، يتم استخراج هذا المؤشر ومقاطعته مع قواعد بيانات السمعة (مثل AbuseIPDB) للتحقق من كونه عنواناً ضاراً.

2. أسماء النطاقات (Domains): يعتمد المهاجمون غالباً على أسماء نطاقات محددة لاستضافة برمجياتهم الخبيثة أو لتوجيه حملات التصيد الاحتيالي (Phishing). وتُعد مراقبة استعلامات الـ DNS (مثل Event ID 22 في Sysmon) حيوية لاكتشاف الاتصال بهذه النطاقات، ويتم إثراؤها آلياً عبر محركات مثل (AlienVault OTX).

3. الروابط التشعبية (URLs): يختلف الرابط عن النطاق في كونه أكثر تحديداً؛ فهو يشير إلى المسار الدقيق للملف الخبيث أو صفحة التصيد داخل الخادم. يُعد ال URL مؤشراً بالغ الأهمية عند تحليل نصوص الأوامر (Command Lines) ، حيث يقوم المهاجمون غالباً باستخدام أدوات مثل (PowerShell أو cURL) لتحميل حمولات خبيثة (Payloads) عبر روابط محددة.

4. قيم التجزئة (File Hashes - MD5, SHA1, SHA256): تمثل قيمة التجزئة "البصمة الرقمية الفريدة" للملف. لا يمكن لمفليّن مختلفين امتلاك نفس قيمة التجزئة، مما يجعلها المؤشر الأكثر دقة وموثوقية (High Fidelity) في إثبات وجود ملف خبيث. تعتمد معمارية النظام المقترح على استخراج هذه القيم (سواء من سجلات Sysmon أو Wazuh FIM) وتمريرها آلياً لمحركات الفحص مثل (VirusTotal) لتأكيد ما إذا كان الملف برمجية خبيثة أم لا.

إن الفهم الدقيق والتصنيف البرمجي لهذه المؤشرات الأربعة يُعد الركيزة الأساسية التي يُبنى عليها "المنطق الشرطي" (Conditional Logic) داخل محركات تنسيق الأتمتة (SOAR)، مما يتيح التوجيه الذكي لكل مؤشر نحو مسار التحقيق المناسب له.

10.2 جمع البيانات الطرفية والمراقبة المجهريّة

للحصول على مؤشرات اختراق دقيقة، لا تكفي سجلات النظام الافتراضية. لذلك يتم الاعتماد على أدوات متخصصة:

1.10.2 أداة Sysmon (System Monitor)

هي خدمة نظام تعمل في الخلفية لتسجيل أدق الأنشطة في بيئة Windows [20] حيث توفر رؤية عميقة عبر معرفات الأحداث، أهمها:

- Event ID 1: تسجيل عملية التشغيل مع السطر البرمجي الكامل، وهو حيوي لكشف السكريبتات المنفذة عبر PowerShell .
- Event ID 3: تسجيل الاتصالات الشبكية الفعلية (عبر عناوين IP) لتتبع حركة البيانات مع خوادم ال (C2).
- Event ID 22: تسجيل طلبات استعلام الأسماء (Domain Name System - DNS) (Queries) لكشف محاولات البحث عن النطاقات (Domains) الخبيثة.
- Event ID 12/13: مراقبة التعديلات على مفاتيح النظام (Registry).

2.10.2 أدوات جمع السجلات

لنقل هذه الأحداث الأمنية من الأجهزة إلى نظام (Wazuh)، تُستخدم أدوات خفيفة الوزن تُعرف ب Log Shippers [21].

- Wazuh Agent: هو أداة لجمع سجلات Windows وإرسالها مباشرةً إلى خادم Wazuh، بما فيها أحداث Sysmon، عبر تكوين قناة Microsoft-Windows-Sysmon/Operational في ملف إعدادات الوكيل (ossec.conf).
- Filebeat: مصمم لجمع ملفات السجلات من أنظمة التشغيل المختلفة كـ Linux.

11.2 بروتوكولات التكامل والربط البرمجي

في بيئات مراكز العمليات الأمنية (SOC) الحديثة، لم تعد الأنظمة الأمنية تعمل ككيانات معزولة، بل تعتمد كفاءة الأتمتة اعتماداً كلياً على قدرة هذه الأنظمة على التواصل والتنسيق فيما بينها وتبادل البيانات التقنية في الوقت الفعلي. ويُعدّ فهم بروتوكولات التكامل الركيزة الأساسية التي توضح كيفية انتقال التنبيه الأمني من مرحلة الكشف (Wazuh) إلى محرك الأتمتة (n8n)، ومن ثم إلى منصات التحقيق والاستجابة (TheHive & Cortex) [7], [22].

1.11.2 واجهات برمجة التطبيقات (API - Application Programming Interface)

تُعدّ واجهات برمجة التطبيقات المعتمدة على بنية (Representational State Transfer - REST) المعيار العالمي واللغة المشتركة لربط الأنظمة البرمجية المختلفة. تعتمد هذه الواجهات على بروتوكول (Hypertext Transfer Protocol / Secure - HTTP/HTTPS) لنقل البيانات، وتتميز بهيكلية "عديمة الحالة" (Stateless)، مما يمنحها السرعة والمرونة اللازمتين للعمل بكفاءة في بيئات الأتمتة [7], [17], [22].

وفي إطار هذا البحث، تُشكل هذه الواجهات الركيزة التقنية الأساسية لتكامل النموذج، إذ يعمل محرك (n8n) كعميل (Client) يقوم بتوجيه طلبات آلية (Requests) مستخدماً دوال برمجية محددة (Methods). فعلى سبيل المثال، يقوم النظام باستخدام الأمر (GET) للاستعلام واسترجاع معلومات التهديدات من منصة (MISP)، بينما يوظف الأمر (POST) لتنفيذ إجراءات فعّالة، مثل توجيه محرك (Cortex) لتشغيل المحللات (Analyzers)، أو الإنشاء الآلي للقضايا (Cases) وإدراج "الملاحظات" (Observables) داخل منصة (TheHive) دون أي تدخل بشري [8], [16]. وتكمن قيمة هذا التكامل

في توحيد العمليات الأمنية مركزياً، مما يعفي المحلل الأمني من عبء التشتت والتنقل بين واجهات المستخدم المتعددة (Multiple Dashboards).

2.11.2 نظام Webhooks

تُمثل تقنية (Webhooks) تطبيقاً عملياً لمفهوم "الدفع اللحظي" للبيانات (Push Mechanism) ، وهي آلية ديناميكية تتيح للأنظمة إرسال معلومات فورية استجابةً لوقوع حدث معين، وذلك دون الحاجة لانتظار طلب استعلام من الطرف المتلقي [7]. وفي إطار المعمارية المقترحة لهذا البحث، تم توظيف هذه التقنية لتلعب دور المحفز الأساسي للأتمتة، حيث تُشكل عقدة الاستقبال (Receive Wazuh Alert) داخل منصة (n8n) نقطة النهاية (Endpoint) المخصصة لانتظار البيانات. وبمجرد أن يرصد نظام (Wazuh) نشاطاً مشبوهاً مثل تنفيذ نص برمجي خبيث تم النقاطه بواسطة أداة (Sysmon)، يقوم النظام مباشرةً "بدفع" تفاصيل التنبيه الأمني عبر مسار (Webhook) المخصص [7]، [23]. وتبرز القيمة التشغيلية لهذه الآلية في قدرتها على إلغاء الحاجة لعمليات "الاستعلام المتكرر" (Polling) المستهلكة للوقت والموارد، مما يضمن انطلاق مسار الأتمتة (Workflow) في ذات اللحظة التي يتولد فيها التنبيه، وهو عامل حاسم وجوهري في تقليص متوسط وقت الاستجابة (MTTR) للتهديدات [13] .

3.11.2 صيغة تبادل البيانات (JavaScript Object Notation - JSON Format)

نظراً للتباين في لغات البرمجة والتقنيات التي بُنيت عليها الأدوات الأمنية المختلفة في هذا البحث (مثل Wazuh، n8n، وTheHive)، برزت الحاجة الماسة إلى لغة تخاطب موحدة تضمن تدفق المعلومات دون أخطاء. وهنا تبرز صيغة (JavaScript Object Notation - JSON) كمعيار قياسي وخفيف الوزن لتبادل البيانات، حيث تعتمد على هيكلية مبسطة تقوم على مبدأ "المفتاح والقيمة" (Key-Value Pairs)، مما يجعلها سهلة القراءة بشرياً وبرمجياً [7]، [22]. وفي إطار سير العمل المقترح، تعتمد هذه الصيغة كحلقة وصل أساسية، إذ يقوم محرك الأتمتة (n8n) باستخدام نصوص برمجية (JavaScript) لتفكيك وتحليل كائنات (JSON) الواردة من تنبيهات نظام (Wazuh). تسمح هذه العملية باستخراج الحقول الأمنية الحساسة بدقة فائقة، مثل عنوان ال IP للمصدر (srcip)، وسطر الأوامر المُنفذ (commandLine)، والقيم المشفرة للملفات (hashes). وبدون هذا التوحيد القياسي لصيغة البيانات، سيصعب تحقيق التكامل السلس بين منصات الكشف المبدئي ومنصات الإثراء الاستخباراتي (Enrichment) [7]، [22].

4.11.2 أثر التكامل البرمجي على كفاءة العمليات الأمنية

يساهم دمج الـ APIs مع الـ Webhooks في تحويل دورة حياة التنبيه الأمني من مسار يدوي بطيء إلى مسار آلي فائق السرعة. يوضح الجدول التالي المقارنة الجوهرية التي يحققها هذا التكامل [13]:

جدول (4.2) مقارنة بين المعالجة اليدوية والمعالجة الآلية

وجه المقارنة	المعالجة اليدوية التقليدية	المعالجة الآلية (عبر APIs & Webhooks)
زمن استلام التنبيه	يعتمد على وقت مراجعة المحلل للشاشة.	لحظي (عبر Webhooks)
إثراء البيانات	البحث اليدوي في VirusTotal/OTX (دقائق)	آلي ومتوازي عبر APIs (ثوان)
توثيق القضية	كتابة التقارير يدوياً في نظام التذاكر.	إنشاء آلي ومفصل في TheHive.
الدقة والاتساق	عرضة للخطأ البشري والنسيان.	دقة عالية وثبات في تطبيق القواعد.

يؤدي هذا التكامل في النهاية إلى تحقيق مفهوم "الاستجابة الرشيقة"، مما يسمح للمؤسسات بالتعامل مع التهديدات المتقدمة في مهدها وقبل أن تتمكن من الانتشار أو التخفي داخل الشبكة.

12.2 التقاطع بين الإطار النظري ونطاق البحث الجاري

بناءً على ما سبق استعراضه في هذا الفصل، يربط هذا البحث بين الجانبين النظري والتطبيقي من خلال تصميم يعتمد كلياً على تكامل الأدوات مفتوحة المصدر لأتمتة الاستجابة للتهديدات. ولتحقيق هذا الهدف، تم تحديد نطاق عملي واضح يركز على أتمتة مراحل محددة من دورة حياة الحادث الأمني، مع استبعاد مراحل أخرى بشكل واضح.

يركز هذا البحث على أتمتة مرحلة التحليل الأولي والفرز التلقائي (Triage)، بالإضافة إلى استخراج وإثراء مؤشرات الاختراق (IOCs) في الوقت شبه الفعلي (Near Real-time). وقد تم اختيار هذه المرحلة تحديداً لأنها تستهلك الجزء الأكبر من وقت وجهد المحللين داخل مراكز العمليات الأمنية (SOCs)، حيث يقضي المحللون معظم وقتهم في فرز التنبيهات والتحقق من المؤشرات يدوياً [5], [13].

من الناحية أخرى، يُنفذ النظام من خلال دمج منصة الكشف (Wazuh) المدعومة بسجلات (Sysmon) التفصيلية مع محرك الأتمتة (n8n)، وذلك بالاعتماد على بروتوكولات الربط القياسية مثل REST APIs و Webhooks). يضمن هذا التكامل تدفق البيانات بشكل آلي وفوري، حيث تُوجه مؤشرات الاختراق إلى محرك التحليل (Cortex) ومنصات استخبارات التهديدات (مثل MISP و OTX) لإثرائها

بالمعلومات الاستخباراتية، وذلك قبل توثيقها وإدارتها كقضايا أمنية متكاملة وجاهزة داخل منصة (TheHive).

وينعكس هذا التكامل مباشرة على تركيز البحث منصّباً بشكل حصري على أتمتة الاستجابة المعتمدة على مؤشرات الاختراق المباشرة (IOC-driven Response)، مما يتيح للمؤسسات تسريع دورة الاستجابة للحوادث وتقليل العبء التشغيلي على المحللين، مع إبقاء إجراءات الاحتواء والاستئصال النهائية تحت الإشراف البشري المباشر.

13.2 الدراسات السابقة

قدمت العديد من الدراسات الأكاديمية والتطبيقات العملية حلولاً لأتمتة العمليات الأمنية وتحسين كفاءة مراكز العمليات الأمنية (SOCs) باستخدام أدوات مفتوحة المصدر. يستعرض هذا القسم أبرز هذه الدراسات، مع التركيز على التكامل بين أنظمة SIEM وSOAR ومنصات استخبارات التهديدات وإدارة الحوادث، وذلك بهدف تحديد الفجوة البحثية التي يسعى هذا العمل إلى سدها.

1.13.2 الدراسات المتعلقة بأنظمة SIEM مفتوحة المصدر (Wazuh)

أظهرت دراسة [3] قدرات أداة Wazuh في كشف الهجمات بناءً على تحليل السجلات، حيث تم التركيز بشكل خاص على كشف هجمات (Secure Shell - SSH brute force). وأوضحت الدراسة أن Wazuh يمكنه رصد محاولات تسجيل الدخول الفاشلة وغيرها من الأنشطة المشبوهة في الوقت الفعلي، مع توفير لوحة تحكم غنية بالمعلومات للمحللين الأمنيين.

من جهة أخرى، قارن [12] بين حلول SIEM مفتوحة المصدر والتجارية، وخلص إلى أن Wazuh يقدم بديلاً فعالاً ومنخفض التكلفة للمؤسسات الصغيرة والمتوسطة، خاصةً فيما يتعلق بقدراته في إدارة السجلات، وكشف التسلل، ومراقبة سلامة الملفات.

كما قدمت [6] دراسة تطبيقية لبناء معمارية SOC متكاملة باستخدام Wazuh كأداة SIEM إلى جانب TheHive لإدارة الحالات وSuricata لكشف التسلل الشبكي. وأظهرت النتائج نجاح النظام في كشف سيناريوهات هجومية متنوعة مثل (Brute Force Attack وحقن SQL وحجب الخدمة) والاستجابة لها، مع تقليل كبير في الجهد اليدوي للمحللين.

2.13.2 الدراسات المتعلقة بأتمتة سير العمل (n8n)

استعرضت دراسة [7] استخدام منصة n8n لأتمتة اكتشاف هجمات SSH brute force والاستجابة لها. تم بناء سير عمل يعتمد على الـ Webhook لاستقبال التنبيهات، وتحليلها، وإرسال إشعارات فورية عبر تطبيق Telegram. وأظهرت النتائج قدرة النظام على رصد جميع محاولات الاختراق (500 محاولة) ومعالجتها في الزمن الحقيقي بكفاءة عالية حتى تحت أحمال الهجوم المرتفعة، مما يؤكد فعالية n8n في السيناريوهات الأمنية الطارئة.

كما تناولت دراسة [22] (على الرغم من تركيزها الأساسي على WordPress) كيفية دمج واجهات برمجة التطبيقات (APIs) الخارجية مع n8n في سياق أمني، حيث تم استخدام n8n لربط نظام المراقبة بمنصات مثل VirusTotal و IPQualityScore، مما يعكس مرونة n8n العالية في التكامل مع مصادر استخبارات التهديدات المختلفة.

3.13.2 الدراسات المتعلقة بإدارة الحوادث وتحليل المؤشرات (Cortex و TheHive)

قدم [16] تقييماً لنضج منصة TheHive كمنصة مفتوحة المصدر للاستجابة للحوادث الأمنية (Security Incident Response Platform - SIRP). وأظهرت الدراسة أن TheHive تلبي معظم متطلبات منصات SIRP من حيث إدارة الحالات (Case Management)، وسير العمل (Workflow)، والتكامل مع MISP و Cortex، مع وجود قصور نسبي في دعم الأدلة الجنائية (Forensic Support) وحفظ الأدلة بشكل آمن.

من ناحية أخرى، أوضح [17] دور Cortex كمحرك تحليل آلي للمؤشرات (Observables) داخل TheHive، حيث يشغل محلات متخصصة للاستعلام عن سمعة المؤشرات من مصادر خارجية متعددة دون أي تدخل بشري.

4.13.2 الدراسات المتعلقة باستخبارات التهديدات ومشاركتها (MISP و OTX)

ناقش [24] تجربة المستخدم (UX) لمنصة MISP كمنصة رائدة لمشاركة معلومات التهديدات. وأشارت الدراسة إلى أن MISP توفر مرونة عالية في تبادل مؤشرات الاختراق (IOCs) والتكتيكات والتقنيات (TTPs) بين المجتمعات الأمنية المختلفة، مما يعزز قدرة المؤسسات على التصدي الاستباقي للتهديدات.

كما أوضح [18] التصميم التقني لـ MISP وآليات المزامنة والتبادل بين العقد المختلفة، مما يجعلها منصة مثالية لبناء استخبارات تهديدات موزعة وموثوقة. بالإضافة إلى ذلك، يعد AlienVault OTX مصدراً

قيماً آخر للتعهد الجماعي للتهديدات، حيث يوفر حزم (Pulses) محدثة يمكن دمجها آلياً في سير العمل الأمني [10].

5.13.2 الدراسات المتعلقة بالتكامل الشامل وأتمتة الاستجابة

قدمت [25] دراسة حول الدفاع الآلي ضد هجمات طبقة التطبيقات على أنظمة Windows باستخدام أداتين مفتوحتي المصدر هما Wazuh كنظام SIEM و Shuffle كمحرك SOAR. وقارنت الدراسة بين سير العمل اليدوي والآلي معتمدةً على ارتباط السجلات (Log Correlation) وكتيبات الاستجابة (Playbooks)، وأظهرت أن الأتمتة تقلل من متوسط زمن الاستجابة (MTTR) وتخفف عبء الفرز اليدوي على المحللين مقارنةً بأنماط ال SOC التقليدية.

كما قدمت [25] أداة (SMS-I) تعتمد على الذكاء الاصطناعي لربط الأحداث السيبرانية والمادية، مع تكامل مع TheHive و MISP، مما يعكس اتجاهًا حديثاً في تطوير مراكز العمليات الأمنية باستخدام تقنيات التعلم الآلي، وهو ما يتوافق مع توجه هذا البحث نحو الأتمتة في التعامل مع التهديدات.

6.13.2 الدراسات المتعلقة بجمع البيانات المتقدمة (Sysmon)

أكدت دراسة [20] على أهمية أداة Sysmon في توفير سجلات تفصيلية على مستوى نظام التشغيل Windows تشمل إنشاء العمليات (Process Creation – Event ID 1) والاتصالات الشبكية (Network Connection – Event ID 3) وتغييرات زمن إنشاء الملفات تساعد في كشف تكتيكات وتقنيات المهاجمين (TTPs) في سياق تتبّع التهديدات (Threat Hunting). وأوضحت الدراسة أن دمج Sysmon مع Wazuh يوسع نطاق السجلات الأمنية المُجمّعة، وهو النهج الذي يعتمد عليه البحث الحالي أيضاً لزيادة دقة الكشف عن السكريبتات الخبيثة والاتصالات الشبكية المشبوهة [20].

7.13.2 المناقشة

من خلال استعراض الأدبيات والدراسات السابقة، تتقاطع النتائج حول عدة محاور رئيسية تؤكد فاعلية الأدوات مفتوحة المصدر، أبرزها:

- Wazuh يمثل حلاً فعالاً ومنخفض التكلفة لأنظمة SIEM/HIDS [1], [3], [12].
- n8n أداة مرنة وقوية لأتمتة سير العمل الأمني والاستجابة للحوادث [7], [22].
- TheHive و Cortex يشكلان منصة متكاملة لإدارة الحوادث وتحليل المؤشرات آلياً، مما يقلل الحاجة للتدخل اليدوي [1], [8], [16].

- MISP و OTX يوفران مصدراً غنياً لاستخبارات التهديدات يمكن دمجها في سير العمل الأمني [10], [18], [24].

- التكامل بين هذه الأدوات المفتوحة المصدر يحسن كفاءة الاستجابة ويقلل الجهد اليدوي للمحللين [1], [26].

ومن خلال تحليل هذه الدراسات لتحديد الفجوة البحثية، يُلاحظ أنه على الرغم من وجود دراسات فردية تناولت كل أداة على حدة، إلا أن الأبحاث التي تقدم نموذجاً متكاملًا يربط بين Wazuh (المدعوم بسجلات Sysmon التفصيلية) و n8n (كمحرك أتمتة) ثم بـ TheHive/Cortex (لإدارة الحوادث والتحليل) و MISP/OTX (لإستخبارات التهديدات) في سير عمل آلي واحد لا تزال نادرة. كما أن معظم الدراسات السابقة ركزت على جوانب محددة مثل الكشف أو الإثراء بشكل منفصل. لذلك، يهدف هذا البحث إلى سد هذه الفجوة من خلال بناء وتقييم هذه المعمارية المتكاملة، وقياس أدائها من حيث زمن الاستجابة (MTTD و MTTR).

الفصل الثالث

منهجية البحث وتصميم النظام

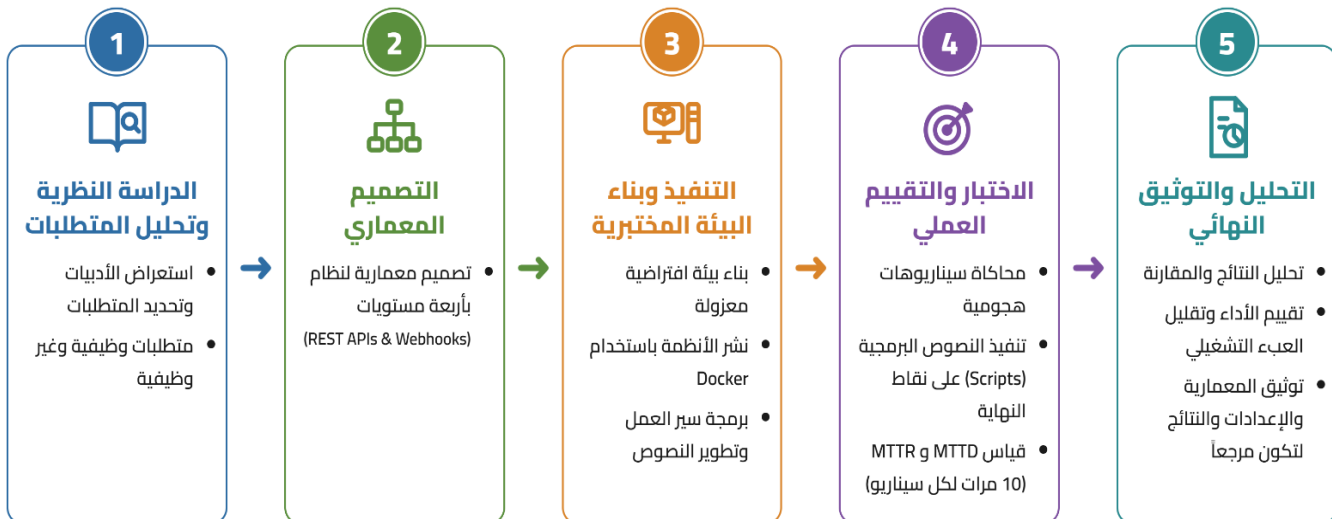
3. تمهيد

يهدف هذا الفصل إلى توضيح المنهجية المتبعة في بناء وتقييم نظام الأتمتة الأمني المقترح، والذي يعتمد كلياً على أدوات مفتوحة المصدر لأتمتة معالجة مؤشرات الاختراق (IOCs) بدءاً من لحظة اكتشافها في التنبيهات الأمنية، ومروراً بعمليات الإثراء والتحليل، وصولاً إلى توثيقها كقضايا أمنية في منصة إدارة الحوادث. يعتمد البحث على المنهجية التجريبية التطبيقية (Experimental & Applied Methodology)، حيث تم تصميم بيئة مختبرية معزولة تحاكي بيئة مراكز العمليات الأمنية (SOCs) في المؤسسات الصغيرة والمتوسطة [2]، [12]. يتضمن هذا الفصل وصفاً تفصيلياً لبيئة البحث، والأدوات المستخدمة، والتصميم المعماري للنظام، ومنطق سير العمل، بالإضافة إلى مؤشرات قياس الأداء المعتمدة.

1.3 منهجية البحث والمتغيرات

1.1.3 مراحل المنهجية المتبعة

لضمان بناء وتقييم النظام الأمني المقترح بأسلوب علمي دقيق وقابل للتكرار، يتم الاعتماد على المنهج التجريبي التطبيقي. وقد نُفذ هذا البحث عبر مسار متسلسل يتألف من خمس مراحل رئيسية كما هو موضح في الشكل (1.3)، حيث صُممت كل مرحلة منها لتحقيق أهداف محددة تمهد للمرحلة التي تليها، وذلك على النحو الآتي:



الشكل (1.3) منهجية البحث

1. **مرحلة الدراسة النظرية وتحليل المتطلبات:** شكّلت هذه المرحلة الأساس المعرفي للبحث، حيث تم استعراض الأدبيات السابقة المتعلقة بأنظمة إدارة المعلومات والأحداث الأمنية (SIEM) وتقنيات التنسيق والأتمتة (SOAR). ومن خلال تحليل الفجوات في الدراسات السابقة، تم تحديد متطلبات النظام المقترح بدقة، والتي انقسمت إلى:

- متطلبات وظيفية: شملت ضرورة توفر قدرات الاستخراج الآلي لمؤشرات الاختراق (IOCs) باستخدام التعبيرات النمطية (Regex)، والقدرة على الفرز الذكي للتنبيهات، والتكامل اللحظي مع قواعد بيانات استخبارات التهديدات.
- متطلبات غير وظيفية: ركزت على ضمان كفاءة الأداء وسرعة المعالجة، والاعتماد الكلي على أدوات مفتوحة المصدر لضمان انخفاض التكلفة التشغيلية، فضلاً عن قابلية النظام للتوسع (Scalability).

2. **مرحلة التصميم الهندسي للمعمارية:** بناءً على المتطلبات المستخلصة، يتم في هذه المرحلة وضع المخططات الهندسية لمعمارية النظام. ولضمان تكامل العمليات وسهولة التتبع، حيث تُقسّم البنية إلى أربع طبقات وظيفية مترابطة عبر واجهات (REST APIs) وأنظمة (Webhooks):

- طبقة المراقبة والكشف: استخدمت (Sysmon) وخادم (Wazuh).
- طبقة الأتمتة والربط: والتي استخدمت محرك (n8n) كعصب مركزي لتنسيق سير العمل.
- طبقة الإثراء الاستخباراتي: وتضمنت منصة (MISP) كمستودع محلي، ومحرك (Cortex) مع محلاته للاتصال بمصادر خارجية.

• طبقة إدارة الحوادث: تمثلت بمنصة (TheHive) لتوثيق القضايا آلياً.

3. **مرحلة التنفيذ وبناء البيئة المختبرية:** انتقلاً من التصميم النظري إلى التطبيق العملي، يتم في هذه المرحلة بناء بيئة افتراضية معزولة باستخدام (VMware). تشمل هذه البيئة إعداد خادم مركزي (Ubuntu 22.04) ونقاط نهاية تعمل بنظام (Windows 11). ولضمان عزل الخدمات ومنع التعارض البرمجي، تم نشر كافة الأنظمة الأمنية (Wazuh, n8n, TheHive, Cortex, MISP) باستخدام تقنية الحاويات (Docker & Docker Compose). وتضمنت هذه المرحلة برمجة سير العمل (Workflow) داخل منصة (n8n) وكتابة نصوص (JavaScript) لمعالجة البيانات بصيغة (JSON).

4. **مرحلة الاختبار والتقييم العملي:** بهدف اختبار كفاءة المنظومة في بيئة تحاكي الواقع، يتم تصميم محاكاة لسيناريوهات هجومية فعلية عبر تنفيذ نصوص برمجية (Scripts) باستخدام موجه الأوامر (Windows Command Prompt - CMD) و (PowerShell) على نقاط النهاية. تستهدف هذه السيناريوهات توليد تنبيهات أمنية تفصيلية لاختبار سرعة ودقة النظام الآلي في

استخراج المؤشرات وإثرائها. ولضمان الموثوقية الإحصائية للنتائج (Statistical Reliability)، يتم تكرار كل سيناريو هجومي (10 مرات)، مع التركيز على قياس وتسجيل مؤشري الأداء الرئيسيين: متوسط زمن الاكتشاف الآلي (MTTD) ومتوسط زمن الاستجابة الآلي (MTTR).
5. مرحلة التحليل والتوثيق النهائي: في المرحلة الختامية، يتم تجميع كافة السجلات والطوابع الزمنية (Timestamps) الناتجة عن مرحلة الاختبار. ويتم تحليل هذه البيانات ومقارنتها بالمتوسطات الزمنية المعروفة للمعالجة اليدوية لتقييم مدى نجاح النظام في تقليص العبء التشغيلي (إرهاق التنبيهات) وتسريع وتيرة الاستجابة. وختاماً، يتم توثيق المخططات المعمارية، وإعدادات التكوين (Configurations)، والنتائج التحليلية في هذا البحث لتكون مرجعاً قابلاً للتطبيق في بيئات مراكز العمليات الأمنية (SOCs).

2.1.3 فروض البحث والمتغيرات

الفرضية الرئيسية: يمكن بناء نظام أتمتة آمني متكامل ومنخفض التكلفة باستخدام أدوات مفتوحة المصدر (Wazuh, n8n, TheHive, Cortex, MISP) يحقق تقليصاً ملحوظاً في زمن الاكتشاف وزمن الاستجابة مقارنة بالمعالجة اليدوية التقليدية.

المتغير المستقل: النظام المقترح (بما يشمل بنيته المعمارية وسير العمل الآلي).

المتغيرات التابعة:

- متوسط زمن الاكتشاف الآلي (Automated MTTD).
- متوسط زمن الاستجابة الآلي (Automated MTTR).
- نسبة النجاح في إتمام دورة المعالجة الآلية عبر التكرارات (Automation Success Rate).
- استقرار الأداء الزمني عبر التكرارات، مُعبّراً عنه بنطاق القيم (Range) بين أدنى وأعلى زمن مسجل لكل سيناريو.

2.3 بيئة البحث والأدوات المستخدمة

يتم بناء البيئة المختبرية باستخدام تقنيات الحوسبة الافتراضية (Virtualization) لتوفير بيئة معزولة وقابلة للتكرار. اعتمدت البيئة على برنامج VMware Workstation لإدارة الأجهزة الافتراضية، حيث يتم تخصيص:

- خادم مركزي واحد: يعمل بنظام التشغيل، Ubuntu 22.04 LTS بمواصفات (6 أنوية معالج، 20 جيجابايت ذاكرة عشوائية، 100 جيجابايت قرص صلب).
- ثلاثة أجهزة افتراضية لنقاط النهاية: تعمل بنظام Windows 11 لكل منها مواصفات (4 أنوية معالج، 8 جيجابايت ذاكرة عشوائية، 60 جيجابايت قرص صلب).

ولضمان كفاءة استهلاك الموارد وسهولة التكامل، يتم الاعتماد على تقنية الحاويات (Docker & Docker Compose) لنشر وتشغيل معظم الأنظمة الأمنية ضمن شبكة افتراضية معزولة.

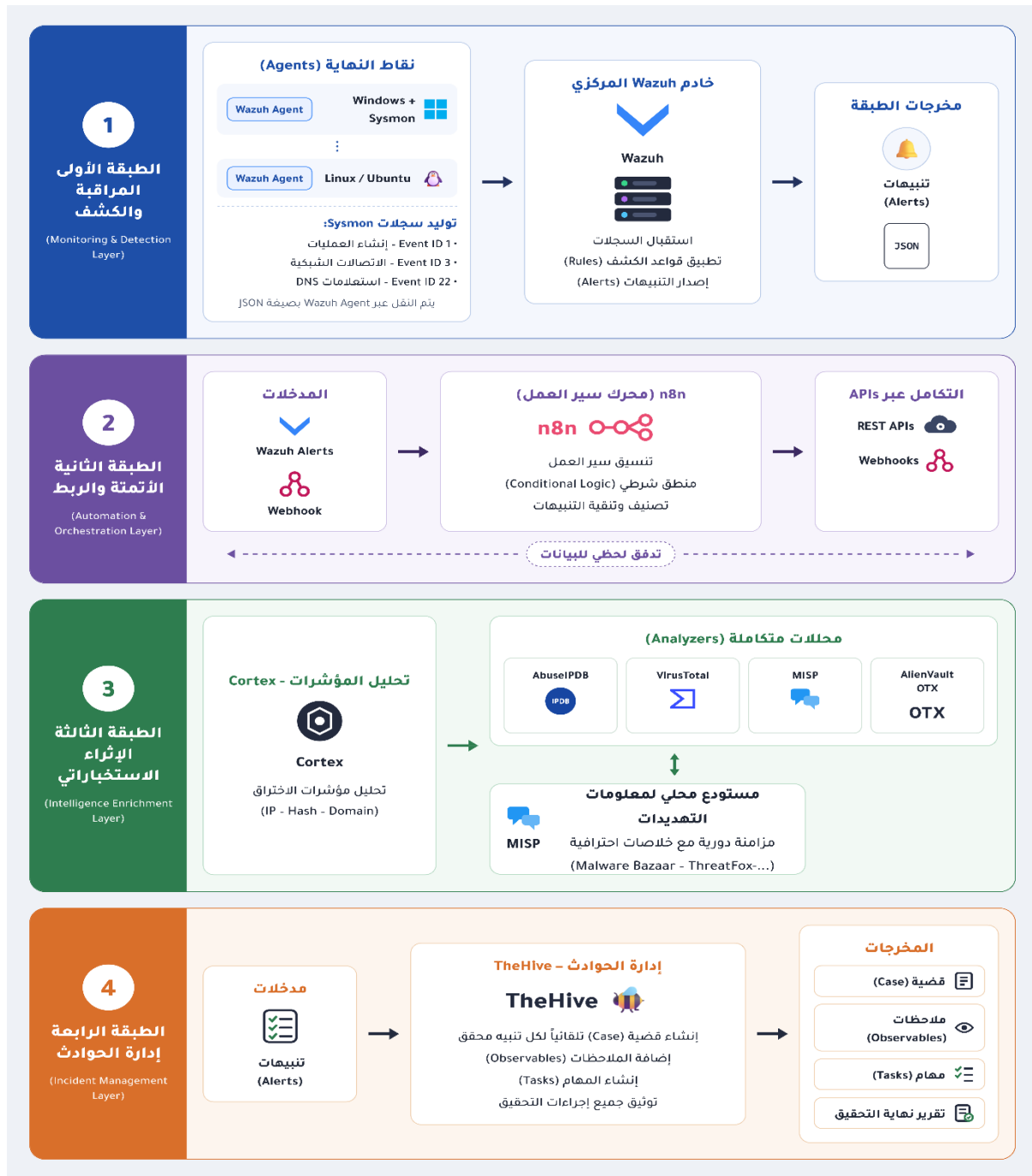
1.2.3 قائمة الأدوات والإصدارات

جدول (1.3) الأدوات المستخدمة في البيئة المخبرية

الأداة	الإصدار	الوظيفة الأساسية
Wazuh	4.7	منصة SIEM/HIDS للمراقبة والكشف
n8n	1.0	محرك أتمتة وتنسيق سير العمل (SOAR)
TheHive	5.1	منصة إدارة الحوادث الأمنية
Cortex	3.1	محرك تحليل آلي للمؤشرات (Observables)
MISP	2.4	منصة استخبارات التهديدات
AlienVault OTX	-	مصدر مجتمعي لمصادر بيانات التهديدات
Sysmon	15	أداة جمع سجلات تفصيلية لنظام Windows
Wazuh Agent	4.7	جمع سجلات Windows/Sysmon وإرسالها إلى خادم Wazuh
VirusTotal	-	محرك فحص سحابي لتحليل الملفات وقيم التجزئة (Hashes) عبر عشرات محركات مكافحة الفيروسات
AbuseIPDB	-	قاعدة بيانات سحابية لتقييم سمعة عناوين الإنترنت (IPs)

3.3 التصميم المعماري للنظام

تم تصميم بنية النظام المقترح وفق نموذج الطبقات (Layered Architecture) الذي يفصل بين مكونات المراقبة، والأتمتة، والإثراء، وإدارة الحوادث، مما يضمن قابلية التوسع والصيانة [6]. تتكون البنية من أربع طبقات رئيسية (كما هو موضح في الشكل 2.3):



شكل (2.3) تصميم بنية النظام المقترح وفق نموذج الطبقات

- الطبقة الأولى: المراقبة والكشف (Monitoring & Detection Layer)

تتكون هذه الطبقة من وكلاء Wazuh المثبتة على نقاط النهاية (بما في ذلك أجهزة Windows المزودة بـ Sysmon)، وخادم Wazuh المركزي الذي يستقبل السجلات ويطبق قواعد الكشف (Rules) ويصدر التنبيهات عند رصد سلوكيات مشبوهة [3], [26]. تقوم أداة Sysmon بتوليد سجلات أحداث تفصيلية تشمل معرفات الأحداث: Event ID 1 (إنشاء العمليات)، Event ID 3 (الاتصالات الشبكية)، Event ID 22 (استعلامات DNS). يتم نقل هذه السجلات مباشرة عبر وكيل Wazuh إلى خادم Wazuh بصيغة JSON.

- الطبقة الثانية: الأتمتة والربط (Automation & Orchestration Layer)

يقوم محرك n8n بدور المحرك المركزي كمسؤول عن تنسيق سير العمل، حيث يستقبل التنبيهات من Wazuh عبر Webhook، وينفذ منطقاً شرطياً (Conditional Logic) لتصنيف التنبيهات وفلترتها، ثم يستدعي واجهات APIs الخاصة بطبقات الإثراء وإدارة الحوادث [7], [26]. تعتمد هذه الطبقة على بروتوكول REST APIs وآلية Webhooks لضمان التدفق اللحظي للبيانات.

- الطبقة الثالثة: الإثراء الاستخباراتي (Intelligence Enrichment Layer)

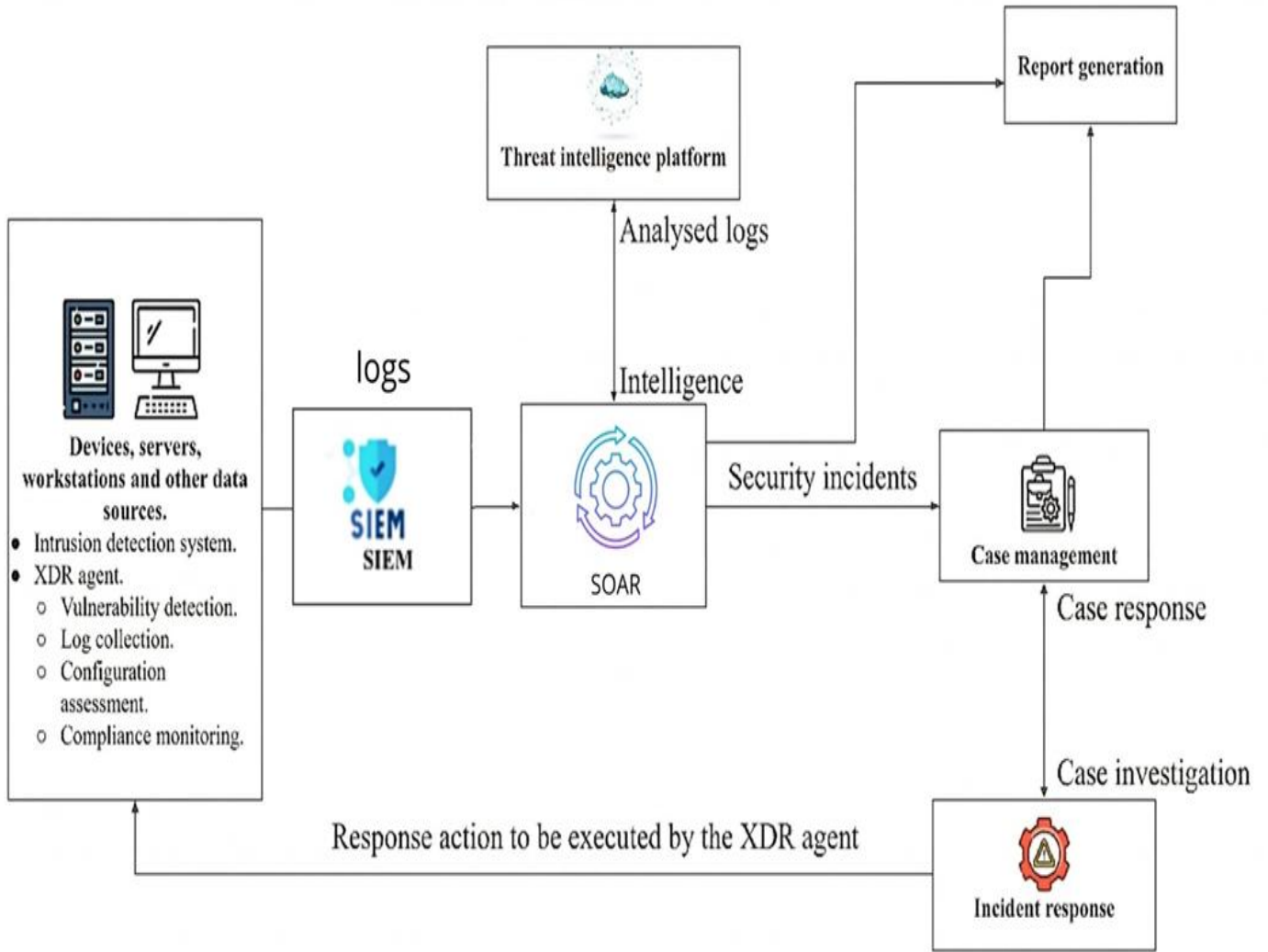
تتولى هذه الطبقة التحقق من صحة مؤشرات الاختراق وإثرائها بمعلومات إضافية من مصادر متعددة. يتم استدعاء Cortex لتحليل المؤشرات (عناوين IP، التجزئات، النطاقات) عبر محلات متكاملة مع AlienVault OTX و MISP و VirusTotal و AbuseIPDB [10], [9], [1]. كما تقوم MISP بدور المستودع المحلي لمعلومات التهديدات، حيث يتم مزامنتها دورياً مع مصادر بيانات التهديدات احترافية (مثل Malware Bazaar و ThreatFox).

- الطبقة الرابعة: إدارة الحوادث (Incident Management Layer)

تتولى منصة TheHive استقبال القضايا الأمنية التي تم إثرائها، وتقوم بإنشاء تنبيه (Alert) تلقائياً، مع إضافة الملاحظات (Observables) والمهام (Tasks) وتوثيق جميع إجراءات التحقيق [8], [17].

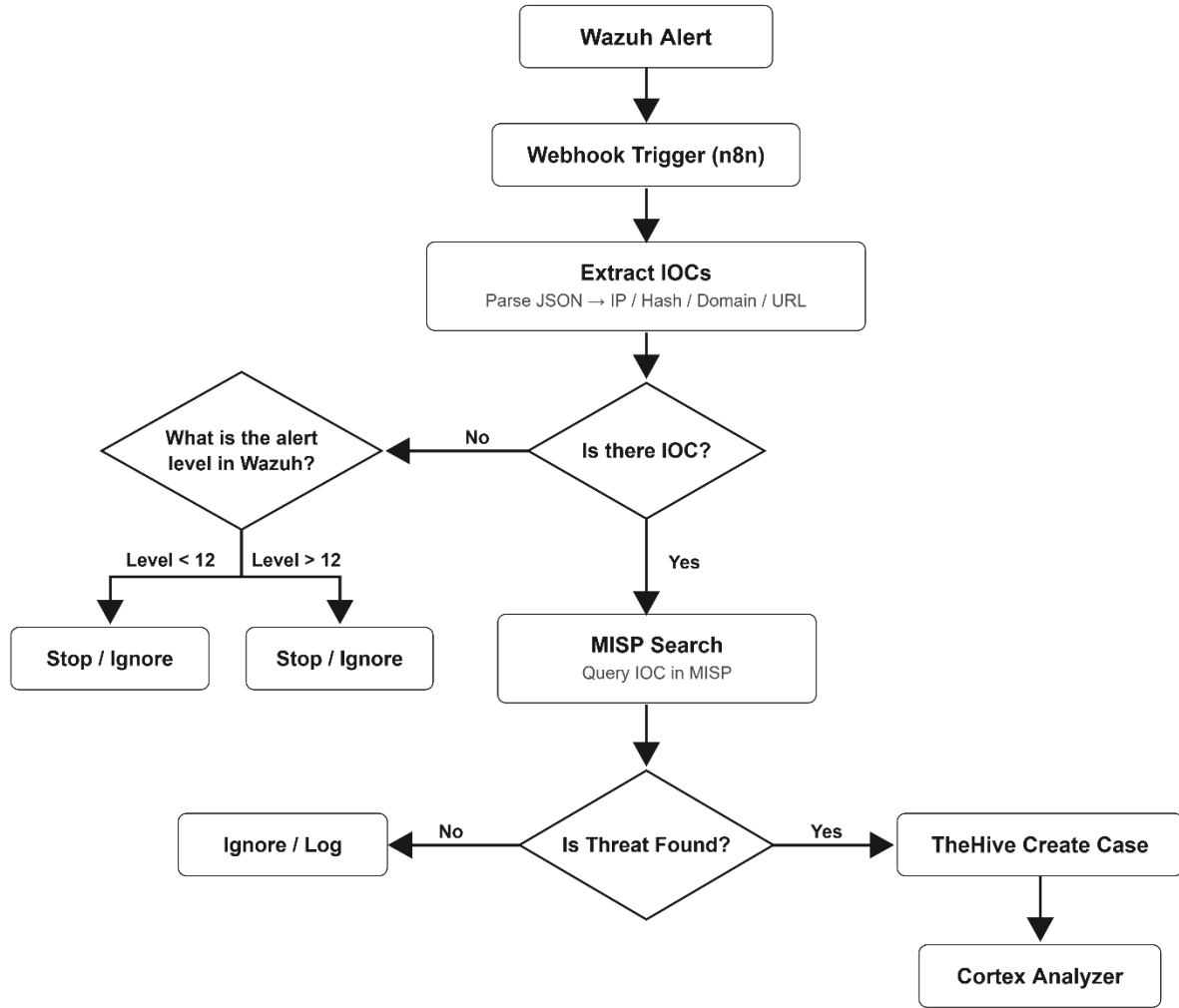
4.3 منطق سير العمل والأتمتة

لضمان تكامل العمليات بين طبقات النظام المختلفة، تنتقل البيانات الأمنية في مسار ديناميكي متسلسل؛ يبدأ من مصادر جمع السجلات وأنظمة (SIEM)، مروراً بمحرك الأتمتة (SOAR) الذي يمثل عقل المنظومة، وانتهاءً بمنصات استخبارات التهديدات وإدارة الحوادث، كما هو موضح في الشكل (3.3) لحركة البيانات داخل المعمارية.



الشكل (3.3) حركة البيانات داخل معمارية النظام

وداخل محرك الأتمتة (n8n) تحديداً، لا تقتصر العملية على مجرد تمرير البيانات، بل يعتمد سير العمل (Workflow) على منطق برمجي دقيق (Conditional Logic) لمعالجة التنبيهات الأمنية. إذ يخضع كل تنبيه لسلسلة متتابعة من القرارات الآلية وعمليات الفرز، والتي يمكن تتبع مسارها بوضوح من خلال المخطط الانسيابي المبين في الشكل (4.3). وتنفذ هذه الآلية عملياً عبر المراحل التفصيلية الآتية:



الشكل (4.3) مخطط انسيابي يوضح منطق سير العمل من الاستقبال إلى الإنشاء

1.4.3 استقبال التنبيه

تنشئ عقدة الاستقبال منفذ Webhook ينتظر استلام البيانات من Wazuh. بمجرد رصد نشاط مشبوه، يتم دفع التنبيه فوراً بصيغة JSON، مما يضمن بدء المعالجة في نفس ثانية وقوع الحدث.

2.4.3 توحيد البيانات واستخراج المؤشرات

يتم كتابة كود JavaScript مخصص لتنفيذ المهام التالية:

- التوحيد (Normalization): تحويل هيكل التنبيه المعقد من Wazuh إلى هيكل مبسط وموحد.
- استخراج المؤشرات عبر التعبيرات النمطية (Regex): مسح النصوص الحرة (مثل أوامر PowerShell) لاستخراج عناوين IP، النطاقات، والتجزئات (Hashes).
- تصفية العناوين الخاصة: استبعاد العناوين المحلية (مثل 127.0.0.1، x.x.192.168) لتركيز التحقيق على التهديدات الخارجية.
- تحديد المؤشر الأساسي: ترتيب أولوية المؤشرات (IP ← URL ← MD5 ← SHA256) لتسهيل عملية البحث الاستخباراتي.

3.4.3 منطق الفرز والقرار

- المسار الاستخباراتي (IOC Match): إذا تم استخراج مؤشرات، يقوم النظام بالاستعلام الفوري من MISP. في حال وجود تطابق، يتم تصعيد التنبيه مباشرة إلى TheHive.
- عتبة الخطورة السلوكية (High Severity): في حال غياب المؤشرات التقنية، يتم فحص مستوى القاعدة (Rule Level) في تنبيه Wazuh. إذا كان المستوى ≤ 12 ، يتم تصعيد التنبيه بناءً على خطورة السلوك المرصود (ضمان عدم إغفال التهديدات الجديدة).

4.4.3 إنشاء القضية والإثراء

في هذه المرحلة يتم بناء وصف فني متكامل للقضية (يشمل تفاصيل الجهاز، رقم القاعدة، وسجل الحدث الأصلي) وإرساله إلى TheHive لإنشاء تنبيه جديد. بعد ذلك، يتم إدراج كل مؤشر (IP، Hash، URL) كـ "ملاحظة" (Observable) منفصلة، ويقوم n8n بتشغيل محلات Cortex المناسبة (VirusTotal للملفات، AbuseIPDB للعناوين، OTX للنطاقات) لإثراء البيانات بشكل متوازي.

الفصل الرابع

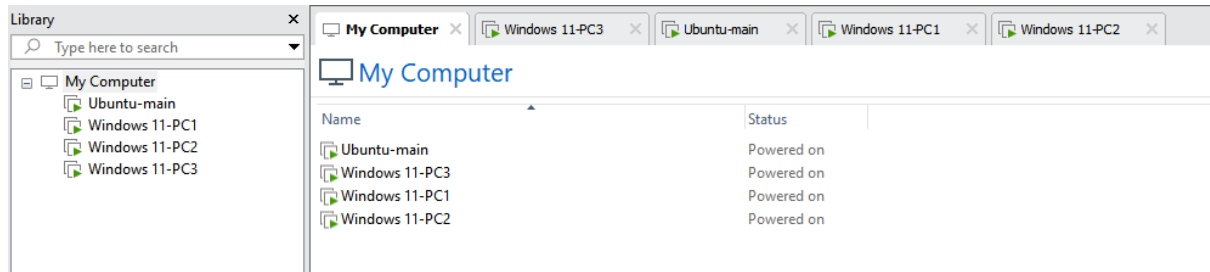
التنفيذ والنتائج

4. تمهيد

يستعرض هذا الفصل الجانب التطبيقي للنظام المقترح، إذ تم تصميم بيئة مختبرية متكاملة تحاكي بيئة مراكز العمليات الأمنية (SOC)، مع التركيز على دور منصة n8n بوصفها محرك التنسيق المركزي (Central Orchestration Engine) الذي يربط بين مكونات الكشف والتحقيق وإدارة الحوادث، بهدف تقليص التدخل البشري وتسريع الاستجابة للتهديدات.

1.4 تنفيذ النظام

تم بناء النظام داخل بيئة افتراضية معزولة باستخدام برنامج VMware، حيث حُصص خادم مركزي يعمل بنظام Ubuntu 22.04 LTS لاستضافة جميع المنصات الأمنية وضمان استقرار الخدمات ومعالجة البيانات. يوضح الشكل (1.4) تفاصيل البيئة الافتراضية والأجهزة المثبتة. واعتمد التنفيذ على تقنية الحاويات (Docker & Docker Compose) لنشر المكونات وإدارتها، مما أتاح مرونةً في الربط الشبكي بينها وفق التالي:



الشكل (1.4) يوضح تفاصيل البيئة الافتراضية

- n8n: محرك التنسيق والأتمتة (SOAR) المسؤول عن تنفيذ مسارات العمل الآلية (Workflows) [7], [22].
- TheHive & Cortex: منظومة إدارة الحوادث والتحليل الآلي للمؤشرات [8], [17].
- MISP: قاعدة بيانات استخبارات التهديدات المحلية والمصدر الرئيسي لمطابقة مؤشرات الاختراق [18], [20].

يوضح الشكل (2.4) الأنظمة المثبتة والمهيأة داخل بيئة Docker.

```
root@ubuntu-VMware-Virtual-Platform:/home/ubuntu/Project-final# docker compose ps
```

NAME	IMAGE	COMMAND	SERVICE	CREATED	STATUS	PORTS
cassandra	cassandra:4.1	"docker-entrypoint.s..."	cassandra	5 weeks ago	Up 8 hours	7000-7001/tcp, 7199/tcp, 9042/tcp, 9160/tcp
cortex	thehiveproject/cortex:latest	"/opt/cortex/entryp..."	cortex	4 weeks ago	Up 8 hours	0.0.0.0:9001->9001/tcp, [::]:9001->9001/tcp
minio	quay.io/minio/minio:latest	"/usr/bin/docker-ent..."	minio	5 weeks ago	Up 8 hours	0.0.0.0:9002->9002/tcp, [::]:9002->9002/tcp, 0.0.0.0:9003->9003/tcp, [::]:9003->9003/tcp
misp	coolacid/misp-docker:core-latest	"/entrypoint.sh"	misp	4 weeks ago	Up 8 hours	0.0.0.0:8080->80/tcp, [::]:8080->80/tcp, 0.0.0.0:8443->443/tcp, [::]:8443->443/tcp
misp-db	mysql:8.0	"docker-entrypoint.s..."	db	5 weeks ago	Up 8 hours	3306/tcp, 33060/tcp
misp-modules	coolacid/misp-docker:modules-latest	"/usr/local/bin/misp..."	misp-modules	4 weeks ago	Up 8 hours	
misp-redis	redis:latest	"docker-entrypoint.s..."	redis	5 weeks ago	Up 8 hours	6379/tcp
n8n	n8nio/n8n:latest	"tini -- /docker-ent..."	n8n	5 weeks ago	Up 8 hours	0.0.0.0:5678->5678/tcp, [::]:5678->5678/tcp
n8n-db	postgres:16	"docker-entrypoint.s..."	n8n-db	5 weeks ago	Up 8 hours	5432/tcp
thehive	strangebee/thehive:5.2	"/opt/thehive/entryp..."	thehive	5 weeks ago	Up 8 hours	0.0.0.0:9000->9000/tcp, [::]:9000->9000/tcp
thehive-es	docker.elastic.co/elasticsearch/elasticsearch:7.17.9	"/bin/tini -- /usr/l..."	thehive-es	5 weeks ago	Up 8 hours	9200/tcp, 9300/tcp

الشكل (2.4) يوضح الأنظمة ومعلومات عنها في Docker

1.1.4 إعداد Wazuh

تم تثبيت خادم Wazuh (الإصدار 4.7) على الخادم المركزي لاستقبال السجلات من نقاط النهاية المراقبة، وشمل الإعداد ما يلي:

- **تثبيت وكلاء Wazuh:** تم تثبيت وكلاء Wazuh على أجهزة Windows 11 الافتراضية التي تمثل نقاط النهاية، وتم تكوينهم لإرسال سجلات الأحداث إلى خادم Wazuh المركزي مباشرة. يوضح الشكل (3.4) واجهة إضافة الأجهزة في Wazuh.
- **تكملة Sysmon:** تم تثبيت Sysmon (الإصدار 15) على أجهزة Windows 11 لجمع سجلات أحداث تفصيلية، تشمل: إنشاء العمليات (Event ID 1)، والاتصالات الشبكية (Event ID 3)، واستعلامات DNS (Event ID 22). يقوم Wazuh Agent بنقل هذه السجلات بصيغة JSON إلى الخادم المركزي للتحليل.

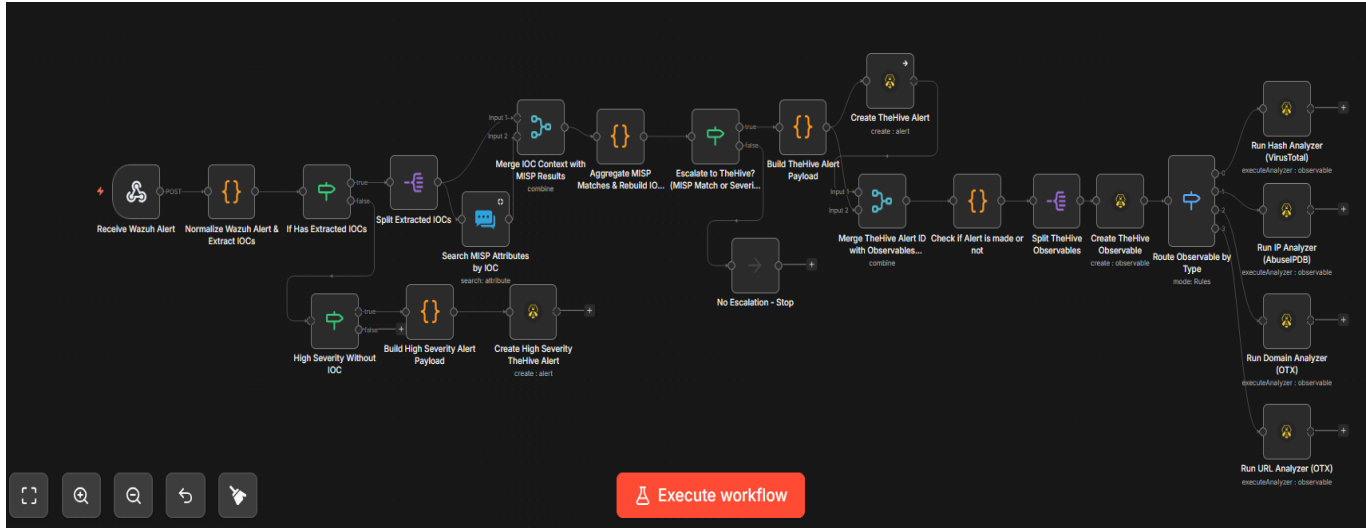
Agents (3)									
Search									WQL
☐	ID	Name ↓	IP address	Group(s)	Operating system	Cluster node	Version	Status	Actions
☐	001	Windows-11	192.168.1.106	default	Microsoft Windows 11 Home 10.0.26200.8037	node01	v4.14.3	disconnected	🔍 ⚙️
☐	002	PC2	192.168.1.10	default	Microsoft Windows 11 Home 10.0.26200.8246	node01	v4.14.4	active	🔍 ⚙️
☐	003	PC-3	192.168.1.12	default	Microsoft Windows 11 Pro 10.0.26200.8246	node01	v4.14.4	disconnected	🔍 ⚙️

الشكل (3.4) يوضح تثبيت الوكلاء في برنامج Wazuh

2.1.4 إعداد n8n

تم نشر منصة (n8n الإصدار 1.0) كحاوية Docker لتعمل بوصفها محرك التنسيق المركزي في النظام، وقد صُمم مسار عمل (Workflow) يربط بين جميع المكونات الأمنية عبر المراحل التالية:

- عقدة الاستقبال (Webhook): تعمل كنقطة دخول رئيسية لاستقبال التنبيهات من خادم Wazuh فور وقوعها، إذ تعتمد على آلية الدفع اللحظي (Push Mechanism) لاستلام البيانات بصيغة JSON، مما يلغي التأخير الناتج عن الاستعلامات الدورية (Polling) ويضمن بدء المعالجة في الزمن الفعلي، وهو ما ينعكس مباشرةً على تقليص زمن الاكتشاف (MTTD).
 - عقدة المعالجة: (Code Node) تتولى استخراج مؤشرات الاختراق من حمولة البيانات الواردة عبر تعابير نمطية (Regex) مخصصة، تُطبَّق على النصوص الحرة كأوامر PowerShell. كما تتضمن هذه العقدة دالة لاستبعاد عناوين الشبكة المحلية (Private IPs) تلقائياً للحد من التنبيهات الكاذبة، إضافةً إلى خوارزمية تحدد مؤشر الاختراق الأساسي (Primary IOC) وفق سُلَّم أولويات.
 - المنطق الشرطي (Conditional Logic): يوجِّه مسار العمل التنبيهات آلياً وفق معطيات الحدث؛ إذ تُحال التنبيهات التي تحتوي على مؤشرات تقنية إلى منصة MISP للتحقق الاستخباراتي، بينما تُصعَّد التنبيهات التي تتجاوز عتبة الخطورة الحرجة ($\text{Level} \geq 12$) إلى TheHive مباشرةً حتى في غياب مؤشرات محددة، مما يضمن عدم إغفال التهديدات غير المعروفة.
 - التنسيق مع واجهات البرمجة (API Orchestration): يتولى n8n إدارة الاتصال مع منصتي Cortex و TheHive عبر واجهات REST API، حيث يُنشئ تنبيهاً أمنياً مكتملاً ويُفعِّل المجلات الخارجية المناسبة لكل نوع من مؤشرات الاختراق بشكل متوازٍ، مما يوفر للمحلل الأمني تقريراً تقنياً شاملاً خلال ثوانٍ دون الحاجة للتدخل اليدوي.
- يوضح الشكل (4.4) مثالاً على مسار العمل (Workflow) في منصة n8n.



الشكل (4.4): يوضح سير العمل (Workflow) في n8n

3.1.4 إعداد منصة إدارة الحوادث (TheHive)

تم نشر منصة TheHive (الإصدار 5.1) كحاوية Docker لتكون المركز الرئيسي لإدارة الحوادث الأمنية وتوثيقها. وتمثل إعدادها في النقاط التالية:

- **استقبال التنبيهات:** تم تكوين المنصة لاستقبال التنبيهات المُصنَّدة برمجياً من محرك n8n، حيث يُزوّد كل تنبيه بعنوان ووصف تفصيلي مستخرج من سجلات Wazuh، ليعمل سجلاً موثقاً لتفاصيل الحادثة ومراحل التحقيق.
 - **إدارة مؤشرات الاختراق (Observables):** تُدرج مؤشرات الاختراق المستخرجة (IP, Hash, Domain, URL) داخل التنبيه كملاحظات فنية مستقلة، مما يسهل على المحلل الأمني تتبعها وربطها بالتهديدات في مراحل التحقيق اللاحقة.
- يوضح شكل (5.4) واجهة TheHive تظهر تنبيهاً أمنياً تم إنشاؤه آلياً مع الملاحظات (Observables) المرفقة.

Description

Wazuh alert enriched by MISP.

Agent: PC2 (192.168.1.10)

Rule ID: 100308

Rule Level: 7

Rule: Suspicious PowerShell Download: IOC detected in Invoke-WebRequest command

Severity: medium

Decoder: windows_eventchannel

Location: EventChannel

Path: N/A

Event Action: N/A

MISP Matches Count: 2

Unique Observables Count: 2

Matched observables:

1. <http://5.75.248.207/cmpbksrv32.cmd> | url | dropped-by-amadey | URLhaus IOCs for 2023-01-26
2. 5.75.248.207 | ip-dst | dropped-by-amadey | URLhaus IOCs for 2023-01-26

Extracted IOCs:

1. <http://5.75.248.207/cmpbksrv32.cmd> | url | win.eventdata.commandLine
2. 5.75.248.207 | ip | derived_from_win.eventdata.commandLine_url

Original log:

N/A

الشكل (5.4): واجهة TheHive تظهر تنبيهاً أمنياً تم إنشاؤه آلياً مع الملاحظات (Observables) المرفقة.

4.1.4 إعداد محرك التحليل الآلي (Cortex)

تم نشر محرك Cortex (الإصدار 3.1) كحاوية Docker ليعمل بوصفه محرك تنفيذ للملاحظات (Analyzers) بشكل آلي، وقد تم إعداداه وفق التالي:

- **التكامل مع TheHive:** تم ربط Cortex بمنصة TheHive بحيث يُشغّل المحللّات الخارجية تلقائياً فور إنشاء التنبيه وإضافة مؤشرات الاختراق إليه.
- **إثراء البيانات:** تم تفعيل وتكوين المحللّات التالية: VirusTotal لفحص بصمات الملفات (Hashes)، و AbuseIPDB للتحقق من سمعة عناوين الشبكة، و AlienVault OTX لتحليل النطاقات والروابط. تظهر نتائج هذه المحللّات مباشرة داخل واجهة TheHive لتدعم المحلل الأمني في تقييم خطورة التهديد واتخاذ القرار المناسب.

يوضح الشكل (6.4) واجهة Cortex تعرض نتائج الإثراء الآلي لمؤشر الاختراق.

```
{
  "summary": {
    "taxonomies": [
      {
        "level": "info",
        "namespace": "OTX",
        "predicate": "Pulses",
        "value": "Number of pulses: 0, Pulses that have a malicious tag: 0"
      }
    ]
  },
  "full": {
    "pulse_count": 0,
    "pulses": [],
    "alexa": "",
    "whois": "http://whois.domaintools.com/5.75.248.207",
    "url_list": []
  },
  "success": true,
  "artifacts": [
    {
      "data": "http://whois.domaintools.com/5.75.248.207",
      "dataType": "url",
      "message": null,
      "tags": [],
      "tlp": 2
    }
  ],
  "operations": []
}
```

Artifacts

#	Datatype	Value
1	url	hxxp://whois[.]domaintools[.]com/5[.]75[.]248[.]207

الشكل (6.4) واجهة محرك Cortex تظهر نتائج الإثراء الآلي لمؤشر الاختراق (Domain Observable)

5.1.4 إعداد منصة استخبارات التهديدات (MISP)

تم نشر منصة MISP (الإصدار 2.4) لتكون المستودع المحلي لبيانات التهديدات، وتؤدي في هذه المعمارية دوراً محورياً في مرحلة الفرز الأولي قبل تصعيد التنبيهات، وذلك وفق التالي:

- **تجميع مصادر بيانات التهديدات (Threat Feeds):** تم تكوين MISP لجلب مصادر بيانات التهديدات وتحديثها من مصادر متخصصة تشمل Malware Bazaar وThreatFox وURLhaus، لبناء قاعدة بيانات محلية محدّثة لمؤشرات البرمجيات الخبيثة. يوضح الشكل (7.4) واجهة MISP التي تعرض هذه التهديدات.

- **التكامل مع n8n:** يستعمل محرك n8n من قاعدة بيانات MISP المحلية للتحقق من مؤشرات الاختراق؛ فإذا وُجد تطابق لأي مؤشر (Hash أو IP أو Domain)، يُصنّف التنبيه فوراً ويُصعد إلى TheHive.
- **التكامل مع Cortex:** يمكن لـ Cortex الاستعلام من MISP كأحد محاليه المتاحين للحصول على السياق التاريخي للمؤشر وتأكيد النتائج داخل واجهة TheHive.

☐	✓	abuse.ch	SOC Alert	— 4292	type:OSINT	tlp:white	2021	24	admin@admin.test	2026-03-26	URLhaus IOCs for 2026-03-26	Organisation	🔗	🗑️	👁️
☐	✓	abuse.ch	SOC Alert	— 4351	type:OSINT	tlp:white	525	24	admin@admin.test	2026-03-26	ThreatFox IOCs for 2026-03-26	Organisation	🔗	🗑️	👁️
☐	✓	abuse.ch	SOC Alert	— 4354	type:OSINT	tlp:white	3805	80	admin@admin.test	2026-03-23	MalwareBazaar malware samples for 2026-03-23	Organisation	🔗	🗑️	👁️
☐	✓	abuse.ch	SOC Alert	— 4358	type:OSINT	tlp:white	2011	104	admin@admin.test	2026-03-22	MalwareBazaar malware samples for 2026-03-22	Organisation	🔗	🗑️	👁️
☐	✓	abuse.ch	SOC Alert	— 4335	type:OSINT	tlp:white	1949		admin@admin.test	2026-03-19	URLhaus IOCs for 2026-03-19	Organisation	🔗	🗑️	👁️

الشكل (7.4): واجهة MISP تعرض التهديدات المحدثة لاستخدامها في الفرز الأولي

6.1.4 تحديات التنفيذ والحلول التقنية

لم تخلُ عملية بناء وتكامل هذه المنظومة الأمنية من التحديات التقنية والعملية، والتي ارتبطت بشكل أساسي بالبنية التحتية والتعقيد البرمجي. ويمكن تلخيص أبرز هذه التحديات وكيفية معالجتها في النقاط التالية:

- **تعقيد استخراج مؤشرات الاختراق (IOC Extraction Complexity):** تمثل بناء عقدة المعالجة (Code Node) تحدياً تقنياً متعدد الجوانب؛ إذ لم يكن الربط بين المكونات مجرد تمرير مباشر للبيانات، بل استلزم تطوير كود JavaScript مخصص لمعالجة حمولة JSON المتداخلة الواردة من سجلات Sysmon. وتمثلت الصعوبة الرئيسية في صياغة تعابير نمطية (Regex) دقيقة لاستخراج مؤشرات الاختراق من النصوص الحرة كأوامر PowerShell دون التسبب في أخطاء المعالجة (Parsing Errors)، إضافةً إلى بناء دوال لتصفية عناوين الشبكة المحلية (Private IPs) آلياً للحد من التنبيهات الكاذبة.

- محدودية موارد الأجهزة المادية (Hardware Limitations): تتطلب محاكاة بيئة مركز العمليات الأمنية (SOC) موارد حوسبة كبيرة من حيث المعالجات والذاكرة العشوائية. وللتغلب على هذا القيد في ظل محدودية الأجهزة المتاحة، تم تصميم بيئة اختبار مصغرة تتكون من خادم مركزي واحد وثلاثة أجهزة Windows 11 افتراضية، وهي بيئة كافية لإثبات صحة المعمارية المقترحة والتحقق من كفاءة آليات الأتمتة.

- قيود واجهات البرمجيات (API Rate Limiting): عند ربط محرك Cortex بالمحطات الخارجية ك VirusTotal و AbuseIPDB، واجه النظام قيوداً على عدد الاستعلامات المسموح بها (Rate Limiting) في الحسابات المجانية. وللتغلب على ذلك، تم تطبيق منطق فرز استباقي داخل n8n بحيث لا تُرسل الاستعلامات إلى هذه الواجهات إلا للمؤشرات التي لم تُطابق مسبقاً في قاعدة بيانات MISP المحلية، مما قلّص الاستهلاك الفعلي لهذه الواجهات بشكل ملحوظ.

2.4 سيناريوهات الاختبار والتحقق العملي

تم تصميم مجموعة من سيناريوهات الاختبار لمحاكاة سلوكيات هجومية واقعية ضمن بيئة نظام Windows، وذلك بهدف تقييم كفاءة النظام المقترح في اكتشاف ومعالجة مؤشرات الاختراق (IOCs) بشكل آلي. وقد ركّزت هذه السيناريوهات على أنواع المؤشرات التقنية الأساسية وهي: عناوين الإنترنت (IP)، وأسماء النطاقات (Domain)، والروابط (URL)، وقيم التجزئة (Hash).

ولضمان موثوقية النتائج، تم تنفيذ كل سيناريو عشر (10) مرات متتالية، مع تسجيل زمن الاكتشاف (MTTD) وزمن الاستجابة (MTTR) لكل محاولة، وملاحظة استقرار القيم الزمنية عبر جميع التكرارات.

كما تم اعتماد معيار تحقق موحد لاعتبار السيناريو ناجحاً، ويتمثل في:

- توليد التنبيه الأمني (Alert) بشكل صحيح داخل منصة TheHive.
 - استخراج مؤشر الاختراق (IOC) بدقة من الحدث.
 - إرفاق نتائج الإثراء الاستخباراتي (Enrichment) داخل التنبيه عند توفرها.
- ويُعد السيناريو ناجحاً عند تحقق جميع الشروط السابقة بشكل متكامل.

1.2.4 السيناريو الأول: تنفيذ أمر PowerShell يحتوي على URL لمحاكاة سلوك تحميل ملف أو تنفيذ عن بُعد

- الهدف: اختبار قدرة النظام على استخراج مؤشرات الاختراق من النصوص الحرة وسطر الأوامر (Command Line)، خاصةً الروابط (URLs) المستخدمة في تحميل الملفات أو تنفيذ أوامر عن بُعد.

مسار المعالجة الآلية:

- تسجيل الحدث عبر Sysmon (Event ID1).
- استقبال الحدث في Wazuh وتحليله.
- استخراج مؤشر الرابط (URL) باستخدام التعبيرات النمطية (Regex).
- تمرير المؤشر إلى منصة MISP للتحقق من وجود تطابق استخباراتي.
- في حال وجود تطابق، يتم إنشاء تنبيه في TheHive وإضافة المؤشرات إليه.
- تشغيل محلل AlienVault OTX عبر Cortex لإثراء البيانات.

2.2.4 السيناريو الثاني: التحقق من اتصال شبكي (TCP) يعتمد على IP مشبوه

- الهدف: اختبار آلية الفرز الأولي (Triage) والتحقق من مؤشرات الاختراق المعتمدة على عناوين الإنترنت (IP) والاتصالات المباشرة باستخدام قاعدة بيانات MISP.

مسار المعالجة الآلية:

- تسجيل الاتصال عبر Sysmon (Event ID 3).
- استخراج مؤشر عنوان الـ IP من الحقل (DestinationIp) وتصفيته لاستبعاد العناوين المحلية.
- تمرير المؤشر إلى منصة MISP للتحقق من وجود تطابق استخباراتي.
- في حال وجود تطابق، يتم إنشاء تنبيه في TheHive وإضافة المؤشرات إليه.
- تشغيل محلل AbuseIPDB عبر Cortex لإثراء البيانات.
- (كما لوحظ استخراج اسم نطاق مرتبط بعنوان IP من الحقل DestinationHostname، والذي يُعد ناتجاً عن عملية Reverse DNS، وتم التعامل معه كمعلومة إضافية ضمن سياق التحليل والإثراء).

3.2.4 السيناريو الثالث: الكشف عن نطاق ضار من خلال استعلام DNS

- الهدف: اختبار قدرة النظام على اكتشاف النطاقات الضارة من خلال استعلامات DNS، والتحقق منها عبر قواعد بيانات التهديدات (Threat Intelligence).

مسار المعالجة الآلية:

- تسجيل الحدث عبر Sysmon (Event ID 22).
- استخراج مؤشر اسم النطاق (Domain) من حقل QueryName.
- تمرير النطاق إلى منصة MISP للتحقق من وجود تطابق استخباراتي.
- في حال وجود تطابق، يتم إنشاء تنبيه في TheHive وإضافة المؤشرات إليه.
- تشغيل محلل AlienVault OTX عبر Cortex لإثراء البيانات.

4.2.4 السيناريو الرابع: تحليل قيم التجزئة (Hash Detection) باستخدام FIM

- الهدف: اختبار كفاءة النظام في مراقبة سلامة الملفات (FIM) واكتشاف التعديلات غير المصرح بها من خلال تحليل قيم التجزئة (Hashes).

مسار المعالجة الآلية:

- اكتشاف التغيير عبر وحدة Syscheck في Wazuh.
 - حساب قيمة التجزئة (SHA256).
 - تمرير قيمة التجزئة (Hash) إلى محرك n8n للتحقق منها داخل منصة MISP.
 - في حال وجود تطابق، يتم إنشاء تنبيه في TheHive وإضافة المؤشرات إليه.
 - تشغيل محلل VirusTotal عبر Cortex لإثراء البيانات.
- وبناءً على تنفيذ السيناريوهات السابقة والتحقق من نجاحها، تم الانتقال إلى مرحلة القياس الكمي لأداء النظام، وذلك من خلال احتساب مؤشري زمن الاكتشاف (MTTD) وزمن الاستجابة (MTTR) لكل سيناريو، كما سيتم توضيحه في القسم التالي.

3.4 قياس الأداء ومؤشراته

لتقييم الكفاءة التشغيلية للنظام المقترح، تم اعتماد منهجية القياس الزمني المقارن بهدف تحليل قدرة النظام على تقليص نافذة التعرض للخطر من خلال قياس زمن الاكتشاف (MTTD) وزمن الاستجابة (MTTR). واستناداً إلى التعاريف النظرية لمؤشري الأداء الواردة في الفصل الثاني، تم تطبيق هذه المؤشرات عملياً ضمن بيئة اختبار معزولة، باستخدام طوابع زمنية دقيقة تم جمعها من مكونات النظام المختلفة، تشمل سجلات Sysmon وواجهة EventViewer ومحرك الأتمتة n8n، مع الاستفادة من الطوابع الزمنية الوسيطة للتحقق من تدفق البيانات بين المكونات.

وللتعامل مع الفجوة الزمنية الطبيعية بين لحظة التنفيذ الفعلي للنشاط المشبوه وتسجيل Sysmon للحدث، والتي تتراوح بين ثانية وثلاث ثوانٍ وتباين باختلاف نوع الحدث، اعتمد القياس على تسجيل لحظة التنفيذ يدوياً لضمان أن قيم MTTD تعكس الزمن الفعلي الكامل منذ لحظة وقوع الحدث.

1.3.4 قياس زمن الاكتشاف الآلي (Automated Mean Time To Detect - MTTD)

تم قياس زمن الاكتشاف (MTTD) باعتباره الزمن المستغرق منذ لحظة تنفيذ النشاط المشبوه وحتى إنشاء التنبيه الأمني داخل منصة TheHive. وقد تم احتساب هذا المؤشر بناءً على الفارق الزمني بين:

- **نقطة البداية:** لحظة تنفيذ النشاط المشبوه على نظام التشغيل (Windows 11)، وقد اعتمد تحديدها على التسجيل اليدوي للحظة التنفيذ.
- **نقطة النهاية:** لحظة إنشاء التنبيه الأمني (Alert) داخل منصة TheHive.
- العمليات الوسيطة (ضمن نطاق القياس):
 - استقبال الحدث في خادم (Wazuh) ومطابقته مع قواعد الكشف.
 - إرسال الحدث عبر واجهة (Webhook) إلى محرك (n8n).
 - استخراج مؤشرات الاختراق (IOCs) باستخدام التعبيرات النمطية (Regex).
 - الاستعلام الأولي والمطابقة مع قاعدة بيانات (MISP).
 - إنشاء التنبيه (Alert) داخل منصة TheHive.

كما تم استخدام الطوابع الزمنية الوسيطة، مثل وقت تسجيل الحدث في Sysmon ووقت استلامه في n8n عبر واجهة Webhook، لأغراض التحقق من صحة انتقال البيانات بين

مكونات النظام. ويعكس هذا المؤشر كفاءة النظام في الكشف المبكر عن التهديدات، إضافةً إلى سرعة انتقال البيانات وتحليلها ضمن بيئة قريبة من الزمن الحقيقي (Near Real-Time).

2.3.4 قياس زمن الاستجابة الآلي (Automated Mean Time To Respond - MTTR)

تم قياس زمن الاستجابة (MTTR) لتقييم كفاءة مسار الأتمتة الأمنية (SOAR) في تنفيذ عمليات التحليل والاستجابة بشكل متكامل. وقد تم احتساب هذا المؤشر باعتباره الفارق الزمني بين لحظة إنشاء التنبيه الأمني داخل منصة TheHive ولحظة اكتمال عملية الإثراء (Enrichment) وظهور نتائج التحليل النهائي:

- **نقطة البداية:** لحظة إنشاء التنبيه (Alert) داخل منصة TheHive.
 - **نقطة النهاية:** لحظة اكتمال الإثراء وظهور نتائج التحليل داخل نفس التنبيه.
 - العمليات الوسيطة (ضمن نطاق القياس):
 - تشغيل عمليات الإثراء عبر منصة Cortex.
 - تنفيذ استعلامات خارجية مثل (AbuseIPDB، AlienVault OTX، VirusTotal).
 - إرفاق نتائج التحليل داخل التنبيه في منصة TheHive.
- اعتمد قياس زمن الاستجابة (MTTR) على Execution Time المسجل داخل واجهة n8n، إذ يُسجل الزمن الفعلي لتنفيذ سير العمل من لحظة استلام التنبيه من TheHive حتى اكتمال عمليات الإثراء وإرفاق نتائجها، وتجدر الإشارة إلى أن عمليتي استخراج مؤشرات الاختراق (IOCs) والتحقق الأولي منها تسبقان إنشاء التنبيه زمنياً، وعليه فهما يُحتسبان ضمن مرحلة الاكتشاف (MTTD) لا مرحلة الاستجابة، مما يضمن الفصل المنهجي الدقيق بين المرحلتين.
- وبعد تحديد منهجية القياس ونقاط احتساب المؤشرات الزمنية، تم تطبيق هذه المنهجية على جميع السيناريوهات التجريبية، واستخراج القيم الفعلية لكل من MTTR و MTTD، والتي سيتم عرضها وتحليلها في القسم التالي.

4.4 النتائج والمناقشة

استناداً إلى السيناريوهات التجريبية الموضحة في القسم (2.4) ومنهجية القياس المعتمدة في القسم (3.4)، تم تنفيذ كل سيناريو عشر (10) مرات، ومن ثم احتساب متوسط زمن الاكتشاف (MTTD) ومتوسط زمن الاستجابة (MTTR) اعتماداً على الطوابع الزمنية المسجلة داخل مكونات النظام.

1.4.4 نتائج القياس الزمني

الجدول (1.4): متوسط القيم الزمنية والنطاق لمؤشري MTTD و MTTR لكل سيناريو اختبار

سيناريو الاختبار (Test Scenario)	نطاق الاكتشاف (ثانية)	متوسط الاكتشاف (ثانية) MTTD	نطاق الاستجابة (ثانية)	متوسط الاستجابة (ثانية) MTTR
تنفيذ سكريبت (PowerShell URL)	4.61 – 3.49	4.02	13.95 – 9.89	10.79
اتصال (TCP (IP+Domain)	7.51 – 4.98	6.26	20.75 – 10.20	11.67
استعلام (DNS (Domain)	6.74 – 4.91	6.09	20.63 – 10.90	14.85
FIM (Hash Detection)	3.98 – 2.50	3.28	40.50 – 10.83	19.04

تمثل القيم الواردة في الجدول نتائج مباشرة للسيناريوهات الأربعة المنفذة، حيث يعكس كل صف أداء النظام في التعامل مع نوع محدد من مؤشرات الاختراق (IOC)، بما في ذلك الروابط (URL)، وعناوين الإنترنت (IP)، وأسماء النطاقات (Domain)، وقيم التجزئة (Hash).

2.4.4 السيناريو الأول: تنفيذ سكريبت (PowerShell URL)

بلغ متوسط زمن الاكتشاف (MTTD) 4.02 ثانية بنطاق (3.49 — 4.61 ثانية)، ومتوسط زمن الاستجابة (MTTR) 10.79 ثانية بنطاق (9.89 — 13.95 ثانية)، مع تحقق نسبة نجاح 100% (10/10 محاولات ناجحة).

يُعدّ متوسط زمن الاكتشاف في هذا السيناريو (4.02 ثانية) ثاني أدنى قيمة بين السيناريوهات الأربعة، ويعكس الزمن اللازم لمعالجة حدث 1 Event ID المرتبط بتنفيذ العمليات، والذي ينطوي على تحليل سطر الأوامر واستخراج المؤشر منه. أما متوسط زمن الاستجابة فقد سجّل أدنى قيمة بين السيناريوهات التي تعتمد على AlienVault OTX.

ومن أبرز ما يميز هذا السيناريو ضيق نطاق الاستجابة (9.89 — 13.95 ثانية) الذي لا يتجاوز فارق 4 ثوانٍ بين أدنى قيمة وأعلىها عبر العشر محاولات، وهو ما يدل على استقرار في أداء النظام عند التعامل مع هذا النوع من المؤشرات خلال جلسة الاختبار.

3.4.4 السيناريو الثاني: اتصال TCP بعنوان IP مشبوه

بلغ متوسط زمن الاكتشاف (MTTD) 6.26 ثانية بنطاق (4.98 — 7.51 ثانية)، وهو الأعلى بين السيناريوهات الأربعة، ومتوسط زمن الاستجابة (MTTR) 11.67 ثانية بنطاق (10.20 — 20.75 ثانية)، مع تحقق نسبة نجاح 100% (10/10 محاولات ناجحة) دون تسجيل التنبيهات كاذبة للعناوين المحلية.

يُسجل هذا السيناريو أعلى متوسط زمن اكتشاف بين السيناريوهات الأربعة (6.26 ثانية)، وإن كان قريباً جداً من سيناريو استعلام DNS (6.09 ثانية) لاشتراكهما في كونهما حدثين شبكيين. ويُعزى هذا الارتفاع مقارنةً بحدث تنفيذ الأوامر (Event ID 1) ومراقبة الملفات إلى طبيعة آلية رصد الاتصالات الشبكية في (Event ID 3) Sysmon التي تستغرق زمناً أطول نسبياً في التسجيل. ورغم ذلك تبقى القيمة ضمن نطاق مقبول لا يتجاوز 7.51 ثانية في أسوأ الحالات.

أما على صعيد زمن الاستجابة، فيلاحظ اتساع نسبي في النطاق (10.20 — 20.75 ثانية) يصل إلى فارق 10 ثوانٍ بين أدنى قيمة وأعلىها، وهو أوسع من نطاق السيناريو الأول ويعكس تأثير تذبذب أداء خدمة AbuseIPDB الخارجية في أوقات مختلفة من التنفيذ. وعلى الرغم من هذا التباين، يبقى المتوسط العام (11.67 ثانية) ضمن نطاق مقبول يعكس كفاءة النظام في التعامل مع مؤشرات IP. وقد أضاف النظام في هذا السيناريو قيمةً تحليليةً إضافية تمثلت في استخراج اسم نطاق مرتبط بعنوان IP من حقل (DestinationHostname) عبر عملية Reverse DNS، مما يثري السياق المتاح للمحلل الأمني دون أي تدخل يدوي.

4.4.4 السيناريو الثالث: استعلام DNS (Domain)

بلغ متوسط زمن الاكتشاف (MTTD) 6.09 ثانية بنطاق (4.91 — 6.74 ثانية)، ومتوسط زمن الاستجابة (MTTR) 14.85 ثانية بنطاق (10.90 — 20.63 ثانية)، مع تحقق نسبة نجاح 100% (10/10 محاولات ناجحة).

يتقارب متوسط زمن الاكتشاف في هذا السيناريو مع السيناريو الثاني 6.09 مقابل 6.26 ثانية، وكلاهما أعلى من السيناريوين الأول والرابع، مما يشير إلى أن أحداث الشبكة بشكل عام سواء (TCP أو DNS) تستغرق زمناً أطول في الاكتشاف مقارنةً بأحداث العمليات أو مراقبة الملفات.

أما متوسط زمن الاستجابة فيُسجل في هذا السيناريو الأعلى بين السيناريوهات التي تعتمد على AlienVault OTX، إذ بلغ متوسطه 14.85 ثانية مقارنةً بـ 10.79 ثانية في السيناريو الأول رغم اشتراكهما في نفس خدمة الإثراء. ويُعزى هذا الفارق إلى تذبذب أداء OTX الخارجي في وقت التنفيذ، وهو سلوك متوقع في الأنظمة التي تعتمد على خدمات استخباراتية خارجية. ويتجلى ذلك أيضاً في اتساع نطاق الاستجابة (10.90 — 20.63 ثانية) الذي يصل فارقه إلى نحو 10 ثوانٍ، مما يؤكد تأثير العوامل الخارجية في تباين الأداء عبر التكرارات المختلفة.

5.4.4 السيناريو الرابع: مراقبة سلامة الملفات FIM (Hash)

بلغ متوسط زمن الاكتشاف 3.28 (MTTD) ثانية بنطاق (2.50 — 3.98 ثانية)، وهو الأدنى بين جميع السيناريوهات. في المقابل سجّل هذا السيناريو أعلى زمن استجابة (MTTR) بمتوسط 19.04 ثانية بنطاق (10.83 — 40.50 ثانية)، مع تحقق نسبة نجاح 100% (10/10 محاولات ناجحة).

يكشف هذا السيناريو عن نمط مثير للاهتمام يتمثل في التناقض بين أدنى متوسط زمن اكتشاف وأعلى متوسط زمن استجابة بين جميع السيناريوهات، مما يؤكد أن المرحلتين مستقلتان تماماً وتتحكم فيهما عوامل مختلفة. فسرعة الكشف عن تعديل الملف لا تعني بالضرورة سرعة الإثراء، إذ يرتبط كل مؤشر من الزمنين بمكون مختلف من مكونات النظام.

ويُعزى انخفاض متوسط زمن الاكتشاف إلى كفاءة وحدة Syscheck في رصد تعديلات الملفات والنقاط التغييرات بشكل فوري، وهو ما انعكس في ضيق نطاق الاكتشاف (2.50 — 3.98 ثانية) الذي لا يتجاوز فارق 1.48 ثانية، وهو ثاني أضيق نطاق اكتشاف بعد السيناريو الأول (1.12 ثانية)، مما يعكس استقراراً عالياً في أداء الكشف. أما ارتفاع متوسط زمن الاستجابة فيرتبط بطبيعة منصة VirusTotal التي تُجري تحليلاً معمقاً عبر عشرات محركات مكافحة الفيروسات، إضافةً إلى قيود معدل الطلبات (Rate Limiting) المفروضة على الحسابات المجانية. وتجلى ذلك بوضوح في القفزة الزمنية التي وصلت إلى 40.50 ثانية في إحدى المحاولات، وهي قيمة تبعد كثيراً عن المتوسط (19.04 ثانية)، مما يدل على أن قيود RateLimiting أثّرت بشكل حاد في تلك المحاولة تحديداً. وعلى الرغم من أن هذه القفزة القصوى لم

تتكرر إلا مرة واحدة، فإن الارتفاع العام في زمن الاستجابة ظل ملحوظاً عبر جلسات الاختبار، مما يؤكد ارتباطه بطبيعة خدمة VirusTotal ذاتها لا بظرف عارض.

6.4.4 موثوقية النتائج

على الرغم من النتائج الإيجابية التي تم تحقيقها، تجدر الإشارة إلى أن هذه القياسات تمت ضمن بيئة اختبار معزولة (Lab Environment)، وقد تختلف القيم الزمنية في البيئات التشغيلية الحقيقية (Production) نتيجة لعوامل مثل:

- حجم البيانات وتعدد مصادر الأحداث
- تعقيد البنية التحتية للشبكة
- عدد الطلبات المرسل إلى الخدمات الخارجية
- قيود واجهات البرمجة (APIs) المستخدمة في الإثراء

لا سيما ما لوحظ من تأثير مباشر لقيود معدل الطلبات (Rate Limiting) على زمن استجابة سيناريو تحليل قيم التجزئة. ومع ذلك، فإن استقرار القيم عبر التكرارات العشر لكل سيناريو يعزز من موثوقية النتائج ويؤكد قابلية تطبيق النظام في بيئات أوسع نطاقاً.

الفصل الخامس

الخلاصة

5. الخلاصة

قدم هذا البحث حلاً عملياً وموثقاً لإشكالية بطء الاستجابة للحوادث السيبرانية وتراكم التنبيهات الأمنية في مراكز العمليات الأمنية (SOCs). ومن خلال تصميم وتنفيذ معمارية أتمتة متكاملة تعتمد بالكامل على حلول مفتوحة المصدر، أثبت البحث أن إدارة دورة حياة مؤشرات الاختراق (IOCs) يمكن أتمتها بنجاح دون الحاجة لتدخل بشري مستمر أو استثمارات مالية ضخمة.

وقد تجلّى نجاح هذا النموذج من خلال القياسات الزمنية التي سُجلت عبر سيناريوهات الهجوم المختلفة؛ حيث حقق النظام قفزة نوعية في الأداء بمتوسط زمن اكتشاف آلي (MTTD) تراوح بين 3.28 و6.26 ثانية، ومتوسط زمن استجابة (MTTR) تراوح بين 10.79 و19.04 ثانية، علماً بأن الحد الأعلى يعود إلى قيود معدل الطلبات على الحسابات المجانية في VirusTotal لا إلى قصور في المعمارية ذاتها. وتعكس هذه القيم تحقيق استجابة بمقياس الثواني، وهو تحسّن جوهري بالمقارنة مع الأزمنة المرجعية للمعالجة اليدوية الموثقة في الأدبيات [5], [13], [25].

يُخلص البحث إلى أن تأسيس استجابة آلية وفعالة للتهديدات السيبرانية أصبح خياراً استراتيجياً وفي متناول المؤسسات الأكاديمية والحكومية في ليبيا وغيرها من البيئات ذات الموارد المحدودة. وبوصفه خطوة تأسيسية نحو النضج الأمني، يوصي هذا البحث مستقبلاً بتوسيع نطاق المعمارية لتشمل خوارزميات تعلم الآلة (Machine Learning) لتحليل السلوك غير النمطي، بالإضافة إلى تقييم أداء النظام عند نشره في بيئات سحابية موزعة وذات كثافة بيانات أعلى.

1.5 التوصيات العملية

بناءً على النتائج، يوصى بالآتي:

- للمؤسسات الصغيرة والمتوسطة: اعتماد النموذج المقترح كنواة لمركز عمليات أمنية (SOC) خاص بها، مع البدء بالأدوات مفتوحة المصدر (TheHive, n8n, Wazuh) قبل الانتقال إلى حلول تجارية، وذلك لخفض التكاليف وبناء الخبرات الداخلية.
- للمؤسسات التعليمية: إدراج هذا النموذج ضمن المناهج العملية في أقسام أمن المعلومات ونظم المعلومات، حيث يوفر بيئة تعليمية واقعية ومنخفضة التكلفة لتدريب الطلاب على مفاهيم SOC وSOAR.

- تطبيق المنطق الشرطي (Conditional Logic) بشكل تدريجي: يوصى بتوسيع منطق الفرز الذكي ليشمل المزيد من السيناريوهات (مثل ربط مستوى الخطورة بنوع الأصل المشتبه به)، مع توثيق جميع "كتيبات الاستجابة" (Playbooks) لضمان قابلية التوسع.
- الاعتماد على مصادر بيانات التهديدات متعددة: يوصى بتغذية منصة MISP بأكثر من مصدر لبيانات التهديدات (Threat Feeds) مثل Malware Bazaar و ThreatFox و URLhaus، وتحديثها دورياً لضمان توفر أحدث مؤشرات الاختراق.
- تدريب المحللين الأمنيين: على الرغم من الأتمتة، يوصى بتدريب المحللين على استخدام واجهات TheHive و Cortex لفهم سير العمل الآلي، وقدرتهم على التدخل اليدوي عند الحاجة (مثل التعامل مع التتبعات الكاذبة النادرة).

2.5 حدود الدراسة وإمكانية تعميم النتائج

حدود البيئة: تم تقييم النظام في بيئة مختبرية معزولة وليس في شبكة إنتاجية حية، لذلك قد تختلف الأداءات (مثل زمن الاستجابة) قليلاً عند التطبيق على نطاق واسع مع آلاف نقاط النهاية.

حدود السيناريوهات: ركز البحث على أربعة سيناريوهات محددة (تنفيذ سكريبت PowerShell مع استخراج روابط URL، الاتصال الشبكي TCP باتجاه عنوان IP خبيث، استعلام DNS إلى نطاق ضار، ومراقبة سلامة الملفات FIM عبر تحليل قيم التجزئة). قد لا تغطي هذه السيناريوهات جميع أنواع الهجمات السيبرانية المعاصرة.

حدود الأتمتة: تمت أتمتة مراحل الكشف والتحليل الأولي والإثراء، بينما بقيت مراحل الاحتواء والاستئصال والتعافي يدوية (خارج نطاق البحث). لذلك، يُنصح بعدم اعتبار النظام حلاً كاملاً للاستجابة الآلية دون تدخل بشري.

حدود الخدمات الخارجية: اعتمدت عمليات الإثراء في الاختبارات على الطبقة المجانية من خدمتي VirusTotal، مما أدى إلى قيود على معدل الطلبات (Rate Limiting) أثرت في قيم MTTR لا سيما في السيناريو الرابع (Hash/FIM) حيث وصلت إلى 40.50 ثانية في إحدى المحاولات. في البيئات الإنتاجية التي تستخدم حسابات مدفوعة أو اشتراكات مؤسسية، يُتوقع انخفاض ملحوظ في هذه القيم.

ومع ذلك، يمكن تعميم النتائج على المؤسسات ذات البنية التحتية المماثلة (أنظمة Windows و Linux) والتي تمتلك ميزانيات محدودة، مع الأخذ بعين الاعتبار التعديلات البسيطة في الإعدادات لتناسب بيئتها الخاصة.

3.5 آفاق التطوير

انطلاقاً من البنية التأسيسية التي حققها هذا البحث في أتمتة مراحل التحليل الأولي، والفرز، والإثراء المبني على مؤشرات الاختراق (IOCs) ، تتبثق عدة مسارات استراتيجية لتوسيع وتطوير هذا النموذج. يمكن للبحوث المستقبلية البناء على هذه المعمارية للارتقاء بمركز العمليات الأمنية عبر الاتجاهات التالية:

- **الانتقال نحو الاستجابة الآلية النشطة (Active Response):** بما أن هذا البحث اقتصر على تجهيز القضية الأمنية، يمكن مستقبلاً توسيع سير العمل (Workflow) ليشمل إجراءات احتواء تلقائية، مثل توجيه أوامر برمجية لحظر عناوين (IP) الخبيثة مباشرة على الجدران النارية (مثل pfSense أو iptables)، أو عزل الأجهزة الطرفية المصابة شبكياً عبر واجهات (API) لأنظمة (EDR).
- **توظيف تقنيات الذكاء الاصطناعي والتعلم الآلي:** ترقية النموذج الحالي عبر إضافة طبقة لتحليل سلوك المستخدم والكيان (UEBA). تعتمد هذه الطبقة على خوارزميات التعلم الآلي لاكتشاف التهديدات المتقدمة وغير المعروفة (Zero-day) التي لا تعتمد على مؤشرات اختراق تقليدية، مما يساهم في تقليل التنبيهات الكاذبة بشكل أدق.
- **تنويع وتقييم حزم الأدوات مفتوحة المصدر:** يمكن للباحثين اختبار مرونة هذه المعمارية عبر استبدال أو دمج أدوات موازية، مثل الاعتماد على حزمة (Elastic Stack – ELK) بدلاً من (Wazuh)، أو استخدام منصة (Shuffle) بدلاً من (n8n) ، وإجراء دراسة مقارنة شاملة للأداء من حيث السرعة، واستهلاك الموارد، وسهولة التكامل.
- **ترحيل النموذج نحو البيئات السحابية (Cloud-based SOC):** إعادة تنفيذ هذه المعمارية باستخدام خدمات البنية التحتية السحابية (مثل AWS أو Azure)، وقياس التحديات المرتبطة بخصوصية البيانات، وزمن انتقال السجلات (Latency) ، وتكاليف التشغيل السحابي مقارنة بالاستضافة المحلية.

- قياس الأثر التشغيلي على العنصر البشري: إجراء دراسة تجريبية وإحصائية تقارن أداء مجموعة من المحللين الأمنيين الذين يعتمدون كلياً على المعالجة اليدوية، بمجموعة أخرى تستخدم هذا النظام الآلي، وذلك لقياس الفروق الدقيقة في معدلات الإرهاق الوظيفي، وعدد التهديدات المكتشفة، وجودة اتخاذ القرار.

يُمثل النموذج مفتوح المصدر المقترح لأتمتة مركز العمليات الأمنية (SOC) خطوة عملية وملموسة نحو تحسين كفاءة الاستجابة للحوادث المعتمدة على مؤشرات الاختراق (IOCs). فمن خلال الدمج الفعّال بين أدوات (MISP, Cortex, TheHive, n8n, Wazuh)، تم تحقيق أتمتة شاملة لدورة حياة معالجة التهديدات، مما أثمر عن تقليص زمن الاستجابة من دقائق وساعات إلى ثوانٍ معدودة [5], [13], [25]، وتخفيف العبء التشغيلي والجهد اليدوي عن كاهل المحللين، مع توفير بديل اقتصادي قوي وقابل للتطبيق. ويأمل الباحثان أن يساهم هذا الجهد العلمي في تشجيع المؤسسات التعليمية، والشركات الناشئة، والقطاعات الحيوية في دولة ليبيا والعالم العربي على تبني الحلول مفتوحة المصدر في مجال الأمن السيبراني، وتطويرها والبناء عليها، سعياً لتحقيق دفاع رقمي أكثر مرونة، وفعالية، واستدامة.

الفصل السادس

المراجع

المراجع

- [1] M. Ishfaq, "An Open-Source SOC Architecture for Automated Detection and Threat Intelligence," *Int. J. Computing & Data Sci*, vol. 01, no. 02, pp. 2025–2026, 2024, doi: 10.71317/IJCDS.001.02.0540.
- [2] AlienVault, "HOW TO BUILD A SECURITY OPERATIONS CENTER (ON A BUDGET)," Sep. 2018.
- [3] Stefan Stanković, Slavko Gajin, and Ranko Petrović, *A Review of Wazuh Tool Capabilities for Detecting Attacks Based on Log Analysis*. Novi Pazar, 2022.
- [4] R. Bhavsar and V. Thakar, "Design and Implementation of an Open-Source Security Operations Center for Effective Cyber Threat Detection and Response," Jan. 20, 2025. doi: 10.21203/rs.3.rs-5795888/v1.
- [5] Courage Ojo, Emmanuel Ayodeji Osoko, Joy Nnenna Okolo, and Mamudat Jaji, "Incident response: A structured model from detection to containment and recovery," *World Journal of Advanced Research and Reviews*, vol. 24, no. 1, pp. 1401–1407, Oct. 2024, doi: 10.30574/wjarr.2024.24.1.3148.
- [6] C. Bassey, E. T. Chinda, and S. Idowu, "Building a Scalable Security Operations Center: A Focus on Open-source Tools," *Journal of Engineering Research and Reports*, vol. 26, no. 7, pp. 196–209, Jun. 2024, doi: 10.9734/jerr/2024/v26i71203.
- [7] N. Alfarizi, R. Rivaldi, and N. Alfarizi Sekolah Menengah Kejuruan Telkom, "Event-Driven Intrusion Detection and Response Automation Using n8n Workflow Platform," *Journal of Technology and Computer (JOTECHCOM)*, vol. 3, no. 1, pp. 16–23, 2026.
- [8] S. Basak and M. Sayeed Hasan Ovi, "The Hive Security Tool: A Scalable and Collaborative Platform for Security Incident Response," 2023.
- [9] A. O. Aljahdali, "A cyber threat intelligence model using MISP and machine learning in a SOC environment," *International Journal of Advanced and Applied Sciences*, vol. 12, no. 11, pp. 1–11, Nov. 2025, doi: 10.21833/ijaas.2025.11.001.
- [10] I. Alzahrani, S. Lee, and K. Kim, "Practical Cyber Threat and OSINT Analysis based on Implementation of CTI Sharing Platform," May 06, 2024. doi: 10.20944/preprints202405.0277.v1.
- [11] I. Security, "Cost of a Data Breach Report 2022," Armonk, Jul. 2022.
- [12] J. Manzoor, A. Waleed, A. F. Jamali, and A. Masood, "Cybersecurity on a budget: Evaluating security and performance of open-source SIEM solutions for SMEs," *PLoS One*, vol. 19, no. 3 March, Mar. 2024, doi: 10.1371/journal.pone.0301183.

- [13] Cody Cornell, "Security Automation A Strategic Imperative for Federal Agencies," 2024. Accessed: Apr. 13, 2026. [Online]. Available: swimlane.com
- [14] G. González-Granadillo, S. González-Zarzosa, and R. Diaz, "Security information and event management (SIEM): Analysis, trends, and usage in critical infrastructures," *Sensors*, vol. 21, no. 14, Jul. 2021, doi: 10.3390/s21144759.
- [15] H. Zahid, S. Hina, M. F. Hayat, and G. A. Shah, "Agentless Approach for Security Information and Event Management in Industrial IoT," *Electronics (Switzerland)*, vol. 12, no. 8, Apr. 2023, doi: 10.3390/electronics12081831.
- [16] A. Groenewegen and J. S. Janssen, "TheHive Project: The maturity of an open-source Security Incident Response platform SNE/OS3.nl-Offensive Technologies: Project Report," Jul. 2021.
- [17] S. Y. Franciscu, "TheHive Project A 4-IN-1 SECURITY INCIDENT RESPONSE PLATFORM," Sri Lanka, Colombo, Nov. 2023.
- [18] C. Wagner, A. Dulaunoy, G. Wagener, and A. Iklody, "MISP - The design and implementation of a collaborative threat intelligence sharing platform," in *WISCS 2016 - Proceedings of the 2016 ACM Workshop on Information Sharing and Collaborative Security, co-located with CCS 2016*, Association for Computing Machinery, Inc, Oct. 2016, pp. 49–56. doi: 10.1145/2994539.2994542.
- [19] Harri Kalikka, "Utilization of Threat Information in Detection Process of Cybersecurity Anomalies," *theseus.fi*, pp. 1–97, Oct. 2024, Accessed: Apr. 22, 2026. [Online]. Available: <https://www.theseus.fi/handle/10024/868035>
- [20] M. Ammi and Y. M. Jama, "Cyber Threat Hunting Case Study using MISP," *Journal of Internet Services and Information Security*, vol. 13, no. 2, pp. 1–29, May 2023, doi: 10.58346/JISIS.2023.I2.001.
- [21] L. F. Ilca, O. P. Lucian, and T. C. Balan, "Enhancing Cyber-Resilience for Small and Medium-Sized Organizations with Prescriptive Malware Analysis, Detection and Response," *Sensors*, vol. 23, no. 15, Aug. 2023, doi: 10.3390/s23156757.
- [22] H. Nuust, "Automated security auditing and monitoring system for WordPress sites," Apr. 2025. Accessed: Mar. 29, 2026. [Online]. Available: <https://www.theseus.fi/handle/10024/907324>
- [23] Y. Ariyanto *et al.*, "Cyber Threat Detection and Automated Response Using Wazuh and Telegram API," *MATRIK : Jurnal Manajemen, Teknik Informatika dan Rekayasa Komputer*, vol. 25, no. 1, pp. 173–188, Nov. 2025, doi: 10.30812/matrik.v25i1.5610.
- [24] B. Stojkovski, G. Lenzini, V. Koenig, and S. Rivas, "What s in a Cyber Threat Intelligence sharing platform?," in *ACM International Conference Proceeding Series*, Association for Computing Machinery, Dec. 2021, pp. 385–398. doi: 10.1145/3485832.3488030.

- [25] E. Maia, N. Sousa, N. Oliveira, S. Wannous, O. Sousa, and I. Praça, “SMS-I: Intelligent Security for Cyber–Physical Systems,” *Information (Switzerland)*, vol. 13, no. 9, Sep. 2022, doi: 10.3390/info13090403.
- [26] A. Thakker, A. More, and K. Kumar, “Automated Defense Against Application-Layer Attacks on Windows Systems Using Wazuh and Shuffle,” *International Journal of Education, Science, Technology, and Engineering (IJESTE)*, vol. 8, no. 1, pp. 45–57, Jun. 2025, doi: 10.36079/lamintang.ijeste-0801.842.

الفصل السابع

الملاحق

الملاحق

يعرض هذا القسم الروابط الرسمية لجميع المنصات والأدوات مفتوحة المصدر والخدمات الخارجية المستخدمة في بناء الإطار المقترح لأتمتة عمليات مركز العمليات الأمنية (SOC)، مع بيان الغرض من كل أداة وتاريخ الدخول إلى موقعها الرسمي للتحقق من توفرها.

الأداة / المنصة	الغرض من الاستخدام	الرابط الرسمي	تاريخ الدخول
Wazuh	منصة SIEM/XDR مفتوحة المصدر للكشف والمراقبة	https://wazuh.com	8 يوليو 2026
Sysmon	أداة مراقبة أحداث نقاط النهاية في أنظمة Windows	https://learn.microsoft.com/en-us/sysinternals/downloads/sysmon	8 يوليو 2026
n8n	محرك أتمتة وتنسيق سير العمل	https://docs.n8n.io/deploy/host-n8n/install-options/install-with-docker	8 يوليو 2026
TheHive	منصة إدارة الحوادث والاستجابة الأمنية	https://docs.strangebee.com/thehive/installation/docker/#step-4-review-the-application-stack	8 يوليو 2026
Cortex	محرك التحليل والإثراء الآلي لمؤشرات الاختراق	https://docs.strangebee.com/cortex/download	8 يوليو 2026
MISP	منصة مشاركة معلومات التهديدات واستخباراتها	https://www.misp-project.org/download	8 يوليو 2026
Docker	منصة الحاويات المستخدمة لنشر مكونات النظام	https://docs.docker.com/desktop/setup/install/linux/ubuntu	8 يوليو 2026
VMware Workstation	برنامج المحاكاة الافتراضية لبيئة الاختبار المعزولة	https://www.vmware.com/products/desktop-hypervisor/workstation-and-fusion	8 يوليو 2026

الأداة / المنصة	الغرض من الاستخدام	الرابط الرسمي	تاريخ الدخول
Ubuntu 22.04 LTS	نظام التشغيل الخاص بالخادم المركزي	https://ubuntu.com	8 يوليو 2026
VirusTotal	خدمة سحابية لفحص وإثراء مؤشرات الاختراق	https://www.virustotal.com	8 يوليو 2026
AbuseIPDB	قاعدة بيانات سمعة عناوين IP	https://www.abuseipdb.com	8 يوليو 2026
AlienVault OTX	منصة مجتمعية لتبادل استخبارات التهديدات	https://otx.alienvault.com	8 يوليو 2026

جميع الروابط أعلاه تم التحقق من توفرها وصلاحياتها بتاريخ 8 يوليو 2026.